CYPHER GROUP INC. · SIMULATED CASE STUDY

CGI-TPR-001 — Third-Party / Vendor Risk Management Programme

Cypher Group Inc. · Version 1.0 · 15 September 2026

> **Case study notice.** Cypher Group Inc. and its seventeen suppliers are simulated. Every organisation, person, system, finding, score, date and figure in this document was created to demonstrate applied GRC methodology. This document is a portfolio artifact and must not be presented as evidence of employment or of a real engagement.

Field	Value
Document ID	CGI-TPR-001
Title	Third-Party / Vendor Risk Management Programme
Version	1.0
Status	Final — issued for management review
Assessment date	15 September 2026
Prepared by (Assessor)	O.S
Approving authority	Jerry Olugboye, Chief Executive Officer
Commissioned by	**CGI-GAP-001 REC-15**, following finding **GAP-006: GV.SC = 0 / 4**
Frameworks	NIST CSF 2.0 (NIST CSWP 29) · ISO/IEC 27001:2022 Annex A · NIST SP 800-30 Rev. 1 · GDPR Articles 28, 30, 32, 33, 46
Risk method	Identical 5 × 5 semi-quantitative method and thresholds as CGI-RSK-001 v1.0
Inputs consumed	CGI-POL-001 to CGI-POL-005 v1.0 · CGI-TRK-001 · EXC-001 to EXC-003 · CGI-RSK-001 v1.0 · CGI-GAP-001 v1.0
Outputs	Vendor inventory (17) · tiering model · 74-question questionnaire · 3 completed assessments · 9 new risks for CGI-RSK-001 v1.1 · lifecycle workflow · clause checklist · 3 reusable templates
Next review	15 September 2027, or on material change

Headline result: 17 vendors inventoried and tiered · 7 Tier 1 · 6 of 17 (35%) operating with no executed Data Processing Agreement · 4 of 17 with no assurance artifact on file · 9 new supplier-originated risks, none of which existed in CGI-RSK-001 v1.0 · GV.SC moves from 0 to 2, closing the declared target gap in a single cycle.

Contents

- **Part 1** — The Why: third-party risk from first principles
- **Part 2** — Vendor inventory
- **Part 3** — Tiering model
- **Part 4** — Vendor security questionnaire
- **Part 5** — Three completed vendor assessments
- **Part 6** — Vendor risk register addendum for CGI-RSK-001 v1.1
- **Part 7** — Onboarding / offboarding workflow and contractual clause checklist
- **Part 8** — One-page executive summary
- **§** — The answer to the commissioning question: GV.SC 0 → 2
- **Appendix A** — Verification, assumptions and limitations
- **Appendix B** — Glossary

Files in this deliverable

File	What it is
`04-vendor-risk-programme.md`	This document.
`04-vendor-risk-programme.pdf`	The same document, formatted for reading or printing.
`04-vendor-risk-programme.xlsx`	The working workbook — live tiering, scoring and risk formulas, dropdowns and colour coding.
`data/04-vendor-inventory.csv`	The full 26-column vendor inventory grid (also the Notion import).
`data/04-tiering-model.csv`	Every vendor's four tiering factors, triggers fired, tier, depth and cadence.
`data/04-vendor-security-questionnaire.csv`	All 74 questions with response type, evidence, weight and dual framework mapping.
`data/04-vendor-assessments.csv`	Summary of the three completed assessments.
`data/04-vendor-risk-register-addendum.csv`	The 9 new risks, scored, ready to merge into CGI-RSK-001 v1.1.
`data/04-vendor-kris.csv`	Seven vendor KRIs with targets, thresholds and owners.
`data/04-contract-clause-checklist.csv`	The 18-clause contractual security checklist.
`../templates/vendor-risk-*-template.*`	Blank `[BRACKETED]` inventory, questionnaire and assessment report.

Part 1 — The Why

1.1 Why this project exists — it was commissioned, not invented

Three prior artifacts point at this work.

Source	What it says	What it obliges
CGI-GAP-001 GAP-006	**GV.SC Cybersecurity Supply Chain Risk Management = 0 / 4.** "Nothing exists in this Category beyond two fragments."	Four Categories scored 0. GV.SC is the only one that is also a hard commercial blocker — enterprise buyers treat a missing vendor register as an immediate fail.
CGI-GAP-001 REC-15	"Build a tiered vendor inventory for CloudCo, CodeCo, ChatCo, OfficeCo and PaymentsCo with assurance artifacts and DPAs, and add permitted third-party destinations to CGI-POL-004 §4.2."	This is the work order. This document is REC-15 executed.
CGI-POL-004 §4.2	The Handling Matrix says how each of the four classification tiers must be handled, but **names no permitted or prohibited third-party destinations**.	A Confidential record can today be pasted into an unvetted SaaS tool **without breaching any written rule**. Part 7.5 closes it.

There is a fourth reason, and it is the honest one. **CGI-RSK-001 v1.0 assessed no supplier-originated scenario at all.** Five risks, R-001 to R-005, and not one of them is "a vendor fails." The register was blind in exactly the direction a 50-person company that runs its entire business on other people's computers is most exposed. Part 6 fixes that with nine new risks.

1.2 What third-party risk is, and why it is a different animal

Third-party risk is the risk that an organisation you have chosen to depend on fails — is breached, goes down, is acquired, changes its terms, or quietly starts doing something with your data you did not agree to — and the consequences land on **you**, in front of **your** customers and **your** regulator.

The definition is easy. What matters is why it cannot be managed like internal risk.

	Internal risk	Third-party risk
Can you fix the control yourself?	Yes. If MFA is off, you turn it on.	**No.** If a provider has weak internal access control, you cannot go and fix it.
What is your actual lever?	Engineering, policy, budget, instruction.	**Contract, assurance evidence, tier, and exit.** That is the entire toolkit.
Can you audit it?	Yes, directly.	Almost never. You audit a *report about them*, written by someone else, about a period that has already ended.
Who carries the liability?	You.	**Still you.** GDPR Article 28 makes the controller responsible for choosing a processor offering sufficient guarantees, and Article 28(4) keeps a processor fully liable for its sub-processor.
How do you learn something went wrong?	Your own logs.	**They tell you. Or the news does.**
How many are there?	One organisation.	Yours, plus theirs, plus theirs. It nests.

> **The governing sentence.** *You can transfer the work, but you cannot transfer the accountability — so the only controls you own over a third party are the ones you wrote into the contract before you signed it, and the only assurance you get afterwards is the evidence you insisted on.*

That is also why this discipline is front-loaded. Every meaningful lever exists **before signature**. After signature you negotiate from weakness, because you have already migrated your data.

1.3 The nesting problem — processor, sub-processor, fourth party

The vocabulary comes from **GDPR** (EU General Data Protection Regulation) and the words are load-bearing legal terms, not synonyms.

- **Data controller** — decides **why** and **how** personal data is processed. Cypher Group Inc. is controller for its own employees' data.
- **Data processor** — processes personal data **on the documented instructions of** a controller. Cypher Group Inc. is a **processor** for its approximately 200 SMB customers' data (CGI-RSK-001 assumption A-06).
- **Sub-processor** — a processor engaged **by a processor**. CloudCo is Cypher Group Inc.'s sub-processor. Under **Article 28(2)** a processor may not engage one without the controller's prior authorisation, and under **Article 28(4)** the processor remains **fully liable to the controller** for the sub-processor's failures.

> **That last clause is the commercial heart of this programme. If CloudCo fails, Cypher Group Inc. is liable to its 200 customers for CloudCo's failure. Not CloudCo. Cypher Group Inc.**

- **Fourth party** — *your vendor's vendor, from where you stand.* A positional word, not a legal one. Continue and you reach **Nth party**, where practical visibility ends.
- **Concentration risk** — many of your vendors quietly depend on the **same** underlying provider, so a single failure removes things you believed were independent. Part 2.5 shows Cypher Group Inc. has exactly this problem, and it becomes risk **VR-002**.

```
CUSTOMER (controller)
   | entrusts data to
   ▼
CYPHER GROUP INC. (processor)          <- liable to the customer for
everything below this line
   | engages
   ▼
CloudCo · OfficeCo · PaymentsCo · …    <- SUB-PROCESSORS (third parties
to us)
   | which themselves engage
   ▼
their own providers                    <- FOURTH PARTIES (largely
invisible to us)
```

1.4 The paperwork — what each artifact proves, and what it does not

The commonest failure in vendor risk is collecting artifacts without knowing what each is evidence *of*. For every one, the useful question is not "do we have it" but **"what claim does this let me make, and what claim does it not let me make?"**

DPA — Data Processing Agreement

A contract mandated by **GDPR Article 28(3)** setting out the subject matter, duration, nature and purpose of processing, the types of personal data and categories of data subject, and the parties' obligations. It must require the processor to act only on documented instructions, impose confidentiality on its staff, implement Article 32 security measures, assist with data subject rights and breach notification, and delete or return the data at the end of the contract.

- **Proves:** obligations exist and are enforceable; a notification pathway exists; sub-processor changes require notice.
- **Does not prove:** that a single control works. **A DPA is a promise, not a measurement.**

BAA — Business Associate Agreement

The US healthcare equivalent, required under **HIPAA** at **45 CFR §164.502(e)** and **§164.308(b)** between a **covered entity** and a **business associate** handling **PHI** (Protected Health Information). Since the HITECH Act, business associates are **directly liable** to regulators — a real difference from the GDPR model, where the controller answers first.

Relevance to Cypher Group Inc.: none today. No PHI is processed. It is defined because it is the most common vendor-risk interview question after "what is a SOC 2", and because **Part 14 switches this entire programme to a HIPAA covered-entity scenario**.

SOC 2 Type II report

SOC = System and Organization Controls, a reporting framework from the **AICPA** (American Institute of Certified Public Accountants). A SOC 2 is an independent CPA firm's report on a service organisation's controls against the **Trust Services Criteria**: **Security** (mandatory — the common criteria), and optionally Availability, Processing Integrity, Confidentiality and Privacy.

	The auditor opines on	CGI-GAP-001 §3.1 equivalent
Type I	Whether controls were **suitably designed** at a **point in time**	**Maturity 2** — design effectiveness
Type II	Whether controls were suitably designed **and operated effectively throughout a period**, normally 3 to 12 months, with tests and results disclosed	**Maturity 3** — operating effectiveness

That mapping is not a coincidence: **Type I : Type II :: maturity 2 : maturity 3** is the same audit distinction used to score all 22 Categories in CGI-GAP-001.

What it does not prove, and where most readers stop:

1. **It is not a pass/fail certificate.** There is no "SOC 2 certified". There is an **opinion** — unqualified, qualified, adverse or disclaimer — and a list of **exceptions** (tests the controls failed). An unqualified opinion can still contain exceptions. **Read Section 4.**
2. **The period has ended.** A report covering 2025 says nothing about today. Hence the "+ Date" in the inventory column, and hence a **bridge letter** — a vendor assertion that nothing material changed since the period end. A bridge letter is not audited.
3. **The scope may exclude the product you use.** Scope lives in the Section 3 system description and is frequently narrower than the marketing implies.
4. **CUECs — Complementary User Entity Controls.** Near the back of every SOC 2 sits a list of controls the auditor **assumed you** were performing. If you are not, the opinion does not cover your usage. Almost nobody reads this list. Reading it is the difference between filing a report and using one — and it is precisely what puts CloudCo into *pass with conditions* rather than *pass* in Part 5.2.

Carve-out vs inclusive method

A **sub-service organisation** is a vendor your vendor relies on, whose controls are needed for your vendor's own control objectives to be met. The vendor's auditor must choose how to treat it and **must state which method was used**:

Method	What the report contains	What it hands you
Carve-out (overwhelmingly common)	The sub-service organisation's controls are **excluded** from the description and **from the opinion**. The report lists **CSOCs** — Complementary Subservice Organization Controls — it *assumes* are operating there.	**Homework.** You must obtain the sub-service organisation's own assurance yourself, read the CSOC list, and confirm those assumed controls exist. The opinion you hold is narrower than it looks.
Inclusive	The sub-service organisation's controls **are** described, **are** tested and **are** covered by the opinion.	Nothing further for that layer. Rare, because it needs the sub-service organisation's cooperation and signature.

> A carve-out report looks like complete assurance and is structurally incomplete. **It is the mechanism by which fourth-party risk becomes invisible.** *"Carve-out or inclusive?"* is the fastest question in existence for separating someone who has read a SOC 2 from someone who has filed one. It is question **VQ-13**, and it carries risk weight 5.

ISO/IEC 27001:2022 certificate

A certificate from an **accredited certification body** stating that an organisation operates an **ISMS** (Information Security Management System) conforming to the standard, **within a stated scope**, on a three-year cycle with annual surveillance audits.

- **Proves:** a management system exists and was audited by an accredited third party, including a risk assessment, a **Statement of Applicability**, management review and continual improvement.
- **Does not prove:**
    1. **Which controls are implemented.** The certificate is one page; the content lives in the **Statement of Applicability**, which vendors rarely release.
    2. **That your product is in scope.** A certificate scoped to "the corporate head office and the ISMS supporting the London development team" does not cover the SaaS platform you are buying. **Reading the scope statement is the highest-yield five seconds in vendor assurance** — it is question **VQ-11**, weight 5, and it asks the vendor to transcribe the scope verbatim precisely so it cannot be paraphrased away.
    3. **That security is good.** ISO 27001 certifies that security is *managed in a structured way*. It is conformance, not performance.

> **In one line.** ISO 27001 asks *"do you run a proper management system?"* SOC 2 Type II asks *"did these specific controls actually work, every time, for the last nine months?"* Neither replaces the other, which is why large vendors hold both.

CAIQ and SIG — the questionnaires

- **CAIQ** — **Consensus Assessments Initiative Questionnaire**, from the **CSA** (Cloud Security Alliance). Standardised questions mapped one-to-one onto the **CCM** (Cloud Controls Matrix); the current release line is **CCM / CAIQ v4.1**. Completed CAIQs are published free on the **CSA STAR registry** — **Level 1 is vendor self-assessment**, Level 2 is third-party audited.
- **SIG** — **Standardized Information Gathering** questionnaire, from **Shared Assessments**, refreshed annually. **SIG Core** is the deep version; **SIG Lite** the short one. Widely used in financial services. The Tier 1 / Tier 2 split in Part 3 is the same idea, purpose-built for this company.
- **Prove:** that the vendor **asserted** something, in a comparable format, as a dated record.
- **Do not prove:** anything, unless independently attested. **A self-assessment is a statement, not evidence.**

So why use one? Three real uses: it is **comparable** across vendors; it is **contractually referenceable**, so a false answer is a misrepresentation you can act on; and **a refusal to complete one is itself a finding**. Use questionnaires to find the questions worth demanding evidence for — never as the evidence.

1.5 "Our vendor is certified" — the sentence that is always wrong

CGI-GAP-001 §9.2 already states the correct position, and this whole programme rests on it:

> **Cypher Group Inc. uses five reputable providers who are themselves well-certified. The score reflects Cypher Group Inc.'s own assurance activity, which is nil. Your vendor's certification is your vendor's control, not yours.**

Three reasons this is not pedantry:

1. **An auditor tests *your* process, not your vendor's paperwork.** ISO 27001 control **A.5.19** requires *you* to have a process for information security in supplier relationships. The evidence is **your** register, **your** tiering decision, **your** dated review, **your** decision record.
2. **The vendor's control set does not cover your configuration.** CloudCo is certified to the hilt and **R-005 still sits at residual 12, High**, in Cypher Group Inc.'s own register. That risk lives entirely on the customer's side of the shared responsibility model. No provider certificate can touch it.
3. **An unread certificate is a file.** Read, scope-checked, recorded against a tier, a data classification, an owner and a review date, it becomes a control.

> **The professional formulation.** *"CloudCo holds SOC 2 Type II and ISO 27001. Our control is that we obtained them, checked the scope and period covered our use, recorded the CUECs we are responsible for, tiered CloudCo as Tier 1, and set a 12-month re-review with a named owner. The certificate is theirs. The process is ours."*

1.6 Vendor tiering — and why it must come first

Tiering classifies each vendor by **how much damage its failure would do to you**, and lets that classification decide how deeply you assess it and how often you re-check.

Why before assessment, not after — three reasons:

1. **Capacity.** A 50-person company with no security hire cannot deeply assess 17 vendors. Untiered, you either assess everything badly or assess whatever came up first.
2. **Defensibility.** "We reviewed SchedulerCo lightly" is indefensible alone. "SchedulerCo scored 3 on the published factors with no escalation trigger, so it is Tier 3 and received the Tier 3 attestation depth, under the same rule that put CloudCo in Tier 1" is a **method**. Auditors and enterprise buyers test whether a repeatable rule exists, not whether you happened to choose well.
3. **It forces the right question first.** Tiering asks *"what would we lose if this vendor failed?"* — the business question. Assessment asks *"what controls do they have?"* — the technical one. Ask the technical question first and you end up with 74 beautifully answered questions about a vendor holding nothing.

The input is your exposure, never the vendor's quality. A vendor's excellence changes the **outcome** of the assessment. It never changes the **tier**. PaymentsCo demonstrates this in the inventory: **Tier 1 by mandatory trigger, yet only Medium inherent risk** — tier and risk score are two different measurements and this document deliberately keeps both.

1.7 Two mechanisms this document uses constantly

① **Left of the bang.** Every control sits on one side of the moment the bad thing happens. The test is not when the control was *prepared* — everything is prepared in advance — but **whether, at the moment of the event, it changes if it happens or only what it costs.**

```
        <- LEFT OF BANG ---------- [EVENT] ---------- RIGHT OF BANG ->
             LIKELIHOOD                                    IMPACT
        MFA, training, patching,                  encryption at rest, tested
backups,
        code review, branch protection,           retention limits,
segmentation,
        vendor assessment before signature        rehearsed IR plan, breach-
```

`notification clause, deletion on exit, insurance`

Brakes reduce likelihood. Seatbelts reduce impact. Both are fitted at the factory. A **DPA is a seatbelt**: it does not make a vendor breach less likely, but its notification clause means Cypher Group Inc. learns in 24 hours rather than from a journalist, which is what makes the CGI-POL-005 §5.6.3 GDPR 72-hour obligation achievable at all.

② **New risk or new route.** A vendor finding either brings a **new event** or a **new route to an existing event**. The decisive question:

> **Would the existing risk's controls have prevented this?** If they are inert against it, it is a **new risk**. If they would have caught it, it is a **new route** and you update the existing risk instead.

Applied in Part 6 to every one of the nine new risks, with the answer written out each time.

Part 2 — Vendor inventory

2.1 How this inventory was built (build narration)

The inventory was not assembled by asking people which tools they use. That method finds the tools people remember. It was built from **four independent discovery sources**, deliberately, because the vendors that matter most are the ones nobody remembers:

#	Source	What it finds	What it found here
1	**Known architecture** — the five providers named in CGI-GAP-001 and CGI-RSK-001	The production stack	CloudCo, CodeCo, ChatCo, OfficeCo, PaymentsCo
2	**Finance — 12 months of card and bank transactions, reconciled line by line**	Anything with a recurring charge, including personal-card expenses	**ScribeCo and WriteCo — neither known to IT, neither under contract**
3	**Identity — OAuth grants and connected apps in OfficeCo**	Anything holding a token against company data, whether or not it was ever paid for	SchedulerCo's calendar read-write scope; WhiteboardCo's directory read scope
4	**Business owners — one 20-minute conversation per function**	Tools bought by a department, and the business reason for them	CRMCo, SupportCo, HRCo, WikiCo, DesignCo — plus LoginCo and MonitorCo from the engineering conversation

> **This is the single most transferable technique in the document.** Source 1 finds what you already knew. **Sources 2 and 3 find what you did not** — and in this exercise they produced two vendors processing Confidential data through AI systems with no contract of any kind. That discovery is now risk **VR-005** (shadow IT) and **VR-006** (third-party AI processing).

Classification is taken from CGI-POL-004's four tiers. **Inherent vendor risk** is scored on the identical NIST SP 800-30 Rev. 1 5 × 5 used in CGI-RSK-001 — likelihood of a vendor-originated incident materially affecting Cypher Group Inc. in a 12-month window, multiplied by impact — using the same thresholds: **Low 1–4 · Medium 5–9 · High 10–14 · Critical 15–25**. **Tier** is computed by the published model in Part 3, never assigned by hand; every tier in the grid below is reproducible from the four factor columns and the trigger column.

2.2 The inventory — 17 vendors

Full 26-column grid, one value per cell, paste-ready: **`data/04-vendor-inventory.csv`**. The view below is the readable one.

CGI-VEN-001

Field	Value
Vendor ID	CGI-VEN-001
Vendor	CloudCo
Service	Cloud hosting and infrastructure for the production platform
Owner (Job Title)	Chief Technology Officer
Class.	Restricted
Hosting	eu-central-1 (Frankfurt), with us-east-1 for backups
Sub-proc.	Y
DPA	Y - 14 Feb 2024
Assurance Held	SOC 2 Type II (period ended 30 Jun 2026) + ISO/IEC 27001, 27017, 27018 - held on file
Tier	**1**
Inherent	**10** High
Status	Assessed - PASS WITH CONDITIONS (VRA-2026-001)
Next Review	15 Dec 2026 (conditions) / 15 Sep 2027 (full)
Risk ID	R-005, R-002
CSF	PR.IR, GV.SC, PR.DS

CGI-VEN-002

Field	Value
Vendor ID	CGI-VEN-002
Vendor	CodeCo
Service	Source code hosting, CI/CD pipeline and secrets store
Owner (Job Title)	Chief Technology Officer
Class.	Confidential
Hosting	United States (multi-region)
Sub-proc.	Y
DPA	Y - 09 Mar 2024
Assurance Held	SOC 2 Type II (period ended 31 Mar 2026) + ISO/IEC 27001 - held on file
Tier	**1**
Inherent	**15** Critical
Status	Assessed - Pass (VRA-2026-004)
Next Review	15 Sep 2027
Risk ID	R-004
CSF	PR.PS, GV.SC

CGI-VEN-003

Field	Value
Vendor ID	CGI-VEN-003
Vendor	OfficeCo
Service	Email, documents, shared drives and primary identity provider
Owner (Job Title)	IT Operations Manager
Class.	Confidential
Hosting	EU and US (global regions)

Field	Value
Sub-proc.	Y
DPA	Y - 22 Jan 2024
Assurance Held	SOC 2 Type II (period ended 31 May 2026) + ISO/IEC 27001, 27017, 27018 - held on file
Tier	**1**
Inherent	**12** High
Status	Assessed - Pass (VRA-2026-005)
Next Review	15 Sep 2027
Risk ID	R-001, R-003
CSF	PR.AA, PR.DS, GV.SC

CGI-VEN-004

Field	Value
Vendor ID	CGI-VEN-004
Vendor	ChatCo
Service	Internal communications, incident channel and customer-facing shared channels
Owner (Job Title)	IT Operations Manager
Class.	Confidential
Hosting	United States
Sub-proc.	Y
DPA	N - NOT EXECUTED
Assurance Held	SOC 2 Type II (period ended 30 Nov 2025) - held on file, 9.5 months stale, no bridge letter
Tier	**1**
Inherent	**12** High
Status	Assessed - FAIL (VRA-2026-002)
Next Review	15 Dec 2026 (re-assessment)
Risk ID	R-001, R-003
CSF	GV.SC, PR.DS, RS.CO

CGI-VEN-005

Field	Value
Vendor ID	CGI-VEN-005
Vendor	PaymentsCo
Service	Payment processing and subscription billing
Owner (Job Title)	Finance Manager
Class.	Restricted
Hosting	United States and Ireland
Sub-proc.	Y
DPA	Y - 05 Apr 2024
Assurance Held	SOC 2 Type II (period ended 30 Apr 2026) + PCI DSS Level 1 AoC + ISO/IEC 27001 - held on file
Tier	**1**
Inherent	**8** Medium
Status	Assessed - Pass (VRA-2026-006)
Next Review	15 Sep 2027

Field	Value
Risk ID	R-005
CSF	GV.SC, PR.DS

CGI-VEN-006

Field	Value
Vendor ID	CGI-VEN-006
Vendor	LoginCo
Service	Customer identity and authentication for the CGI platform
Owner (Job Title)	Chief Technology Officer
Class.	Confidential
Hosting	eu (Frankfurt) tenant
Sub-proc.	Y
DPA	Y - 17 Jun 2024
Assurance Held	SOC 2 Type II (period ended 28 Feb 2026) + ISO/IEC 27001 - held on file
Tier	**1**
Inherent	**10** High
Status	Assessed - Pass (VRA-2026-007)
Next Review	15 Sep 2027
Risk ID	R-001, R-004
CSF	PR.AA, GV.SC

CGI-VEN-007

Field	Value
Vendor ID	CGI-VEN-007
Vendor	MonitorCo
Service	Application performance monitoring and application log search (engineering use; not configured as a security log source)
Owner (Job Title)	Chief Technology Officer
Class.	Confidential
Hosting	eu1 (Frankfurt)
Sub-proc.	Y
DPA	Y - 11 Nov 2025
Assurance Held	SOC 2 Type II (period ended 30 Jun 2026) + ISO/IEC 27001 - held on file
Tier	**1**
Inherent	**12** High
Status	Assessed - Pass (VRA-2026-008)
Next Review	15 Sep 2027
Risk ID	R-003, R-005
CSF	DE.CM, GV.SC

CGI-VEN-008

Field	Value
Vendor ID	CGI-VEN-008

Field	Value
Vendor	CRMCo
Service	CRM, marketing automation and customer lifecycle management
Owner (Job Title)	Head of Customer Success
Class.	Confidential
Hosting	EU (Frankfurt) data centre
Sub-proc.	Y
DPA	Y - 30 Aug 2024
Assurance Held	SOC 2 Type II (period ended 31 Jan 2026) - held on file
Tier	**2**
Inherent	**12** High
Status	Assessed - Pass with observation
Next Review	15 Mar 2028
Risk ID	R-003
CSF	GV.SC, PR.DS

CGI-VEN-009

Field	Value
Vendor ID	CGI-VEN-009
Vendor	SupportCo
Service	Customer support ticketing and help centre
Owner (Job Title)	Head of Customer Success
Class.	Confidential
Hosting	EU (Frankfurt)
Sub-proc.	Y
DPA	Y - 14 Oct 2024
Assurance Held	SOC 2 Type II (period ended 31 Mar 2026) + ISO/IEC 27001 - held on file
Tier	**2**
Inherent	**9** Medium
Status	Assessed - Pass
Next Review	15 Mar 2028
Risk ID	R-001, R-003
CSF	GV.SC, RS.CO

CGI-VEN-010

Field	Value
Vendor ID	CGI-VEN-010
Vendor	HRCo
Service	HR information system, employee records and onboarding workflow
Owner (Job Title)	Head of People and Operations
Class.	Confidential
Hosting	EU (Germany)
Sub-proc.	Y
DPA	Y - 03 Feb 2025

Field	Value
Assurance Held	ISO/IEC 27001 - held on file. No SOC 2 published
Tier	**2**
Inherent	**6** Medium
Status	Assessed - Pass
Next Review	15 Mar 2028
Risk ID	R-003
CSF	GV.SC

CGI-VEN-011

Field	Value
Vendor ID	CGI-VEN-011
Vendor	WikiCo
Service	Internal knowledge base, runbooks and project documentation
Owner (Job Title)	Chief Technology Officer
Class.	Confidential
Hosting	United States
Sub-proc.	Y
DPA	N - NOT EXECUTED (team plan, DPA never countersigned)
Assurance Held	SOC 2 Type II (period ended 31 Dec 2025) - vendor publishes, NOT obtained by CGI
Tier	**2**
Inherent	**9** Medium
Status	Assessed - Pass with conditions
Next Review	15 Mar 2028
Risk ID	R-003
CSF	GV.SC, PR.DS

CGI-VEN-012

Field	Value
Vendor ID	CGI-VEN-012
Vendor	ScribeCo
Service	AI meeting transcription and summarisation (joins customer and internal calls)
Owner (Job Title)	Head of Customer Success
Class.	Confidential
Hosting	United States
Sub-proc.	N - not disclosed
DPA	N - NO CONTRACT OF ANY KIND
Assurance Held	None held
Tier	**2**
Inherent	**16** Critical
Status	SHADOW IT - discovered 15 Sep 2026 in expense review; assessment in progress
Next Review	15 Oct 2026 (decision due)
Risk ID	R-003
CSF	GV.SC, PR.DS, GV.OC

CGI-VEN-013

Field	Value
Vendor ID	CGI-VEN-013
Vendor	WriteCo
Service	AI writing assistance browser extension
Owner (Job Title)	Head of People and Operations
Class.	Confidential
Hosting	United States
Sub-proc.	N - not disclosed
DPA	N - individual licences on expense
Assurance Held	None held (vendor publishes SOC 2 Type II - not obtained by CGI)
Tier	**2**
Inherent	**12** High
Status	Assessed - Pass with conditions (extension scope restricted)
Next Review	15 Mar 2028
Risk ID	R-003
CSF	GV.SC, PR.DS

CGI-VEN-014

Field	Value
Vendor ID	CGI-VEN-014
Vendor	DesignCo
Service	Product and interface design
Owner (Job Title)	Chief Technology Officer
Class.	Internal
Hosting	United States
Sub-proc.	Y
DPA	Y - 19 May 2025
Assurance Held	SOC 2 Type II (period ended 30 Apr 2026) - held on file
Tier	**3**
Inherent	**4** Low
Status	Assessed - Accepted (light touch)
Next Review	15 Sep 2028
Risk ID	-
CSF	GV.SC

CGI-VEN-015

Field	Value
Vendor ID	CGI-VEN-015
Vendor	SchedulerCo
Service	External meeting scheduling
Owner (Job Title)	Head of Customer Success
Class.	Confidential
Hosting	United States

Field	Value
Sub-proc.	Y
DPA	Y - 08 Jul 2025
Assurance Held	SOC 2 Type II (period ended 28 Feb 2026) - held on file
Tier	**3**
Inherent	**4** Low
Status	Assessed - ACCEPTED with documented justification (VRA-2026-003)
Next Review	15 Sep 2028
Risk ID	-
CSF	GV.SC

CGI-VEN-016

Field	Value
Vendor ID	CGI-VEN-016
Vendor	WhiteboardCo
Service	Collaborative whiteboarding for workshops and architecture sessions
Owner (Job Title)	Chief Technology Officer
Class.	Internal
Hosting	EU and US
Sub-proc.	Y
DPA	N - NOT EXECUTED
Assurance Held	None held (vendor publishes SOC 2 Type II - not obtained by CGI)
Tier	**3**
Inherent	**4** Low
Status	Assessed - Accepted (light touch), DPA action open
Next Review	15 Sep 2028
Risk ID	-
CSF	GV.SC

CGI-VEN-017

Field	Value
Vendor ID	CGI-VEN-017
Vendor	StatusCo
Service	Public service status page (required by CGI-GAP-001 REC-14)
Owner (Job Title)	Head of Customer Success
Class.	Public
Hosting	United States
Sub-proc.	Pending
DPA	Pending - in contract review
Assurance Held	None held - onboarding in progress
Tier	**3**
Inherent	**4** Low
Status	ONBOARDING - in assessment under the CGI-TPR-001 workflow
Next Review	On go-live

Field	Value
Risk ID	R-002
CSF	RC.CO, GV.SC

The three assessments in Part 5 are published in full. VRA-2026-004 to -008 and the Tier 2 and Tier 3 reviews are recorded in the inventory only.

2.3 Data types and volumes

Vendor ID	Vendor	Data Types	Volume / Criticality	Assessor note
CGI-VEN-001	CloudCo	Customer account data, project content, payment metadata, backups, application logs	All production data for approx. 200 customers / Critical	Carve-out method; four CUECs unaccepted. No CIS baseline on the CGI side (CG-03).
CGI-VEN-002	CodeCo	Application source code, infrastructure-as-code, CI secrets, deployment credentials	100% of the codebase / Critical	No branch protection on the CGI side (CG-02). Vendor control strong; our use of it is not.
CGI-VEN-003	OfficeCo	Internal documents, employee email, contracts, limited customer PII	50 mailboxes, all internal documents / High	No data-egress monitoring on the CGI side (CG-05). Acts as IdP, so a compromise is estate-wide.
CGI-VEN-004	ChatCo	Internal discussion, pasted credentials and screenshots, incidental customer PII, incident traffic	50 users, 3 shared channels with customers / High	No DPA; no SCIM so CGI-POL-003 4.5.2 four-hour revocation is not technically achievable; unlimited retention; guest access uncontrolled.
CGI-VEN-005	PaymentsCo	Billing contact details, payment metadata, invoices. No PAN held by CGI (AVD-001)	approx. 200 billing relationships, USD 3.6M ARR / High	Tier 1 by Restricted-data trigger yet only Medium inherent risk - tier and score are different measures.
CGI-VEN-006	LoginCo	Customer end-user identifiers, credentials, session and MFA enrolment data	approx. 9,000 end-user identities across 200 customers / Critical	Single point of authentication failure for every customer tenant.
CGI-VEN-007	MonitorCo	Production application logs, infrastructure telemetry, traces containing customer identifiers	All production log traffic / High	Log scrubbing rules not verified; agent holds read access across production hosts.
CGI-VEN-008	CRMCo	Customer and prospect contact PII, commercial terms, support correspondence	approx. 200 customer accounts plus approx. 4,000 prospect records / Medium	Largest single concentration of contact PII outside the platform. Marketing integrations not inventoried.
CGI-VEN-009	SupportCo	Support tickets, customer screenshots and attachments, occasional credentials pasted by users	approx. 350 tickets per month / Medium	Attachment content is the exposure, not the ticket text.
CGI-VEN-010	HRCo	Employee personal data, contracts, payroll reference data, onboarding records	50 employee records / Medium	Feeds the CGI-POL-003 joiner-mover-leaver process; an outage delays revocation evidence.
CGI-VEN-011	WikiCo	Internal procedures, architecture notes, meeting records, occasional customer names	approx. 1,200 pages / Medium	Public-share links are enabled tenant-wide and have never been audited.

Vendor ID	Vendor	Data Types	Volume / Criticality	Assessor note
CGI-VEN-012	ScribeCo	Full audio and transcripts of internal and customer calls, including commercial and security discussion	approx. 40 meetings per month / Medium	Procured on a personal card. Breaches CGI-POL-001 4.5 (AI use). Model-training terms unreviewed.
CGI-VEN-013	WriteCo	Any text typed into any web field, including ChatCo, WikiCo, the CGI admin console and email	12 seats / Medium	Scored 3 on the tiering factors; escalated to Tier 2 by trigger T2-f. Reads Confidential text by design.
CGI-VEN-014	DesignCo	UI designs, unreleased feature mock-ups, marketing assets. No customer data	8 seats / Low	Roadmap confidentiality is the only exposure.
CGI-VEN-015	SchedulerCo	Invitee name, email address, meeting subject line. No account or platform data	approx. 120 bookings per month / Low	Calendar read-write scope is the only privilege of note. Replaceable within one business day.
CGI-VEN-016	WhiteboardCo	Architecture diagrams, workshop output, retrospective notes	20 seats / Low	Architecture diagrams are a reconnaissance aid if the board is publicly shared.
CGI-VEN-017	StatusCo	Incident status text and subscriber email addresses only	approx. 200 subscribers expected / Low	First vendor onboarded through the new workflow; used as the worked example in Part 7.

2.4 What the inventory says before a single assessment was run

Finding	Number	Why it matters
Vendors in scope	**17**	Three and a half times the five previously known. The estate was never the stack.
Tier 1 — Critical	**7**	Each one, failing, is a customer-visible or data-loss event.
Tier 2 — Important	**6**	
Tier 3 — Limited	**4**	
Operating with no executed DPA	**6 of 17 (35%)**	5 never executed, 1 pending. Four of the six already hold Confidential data (ChatCo, WikiCo, ScribeCo, WriteCo). **A GDPR Article 28 gap today, not a future risk.** → **VR-001**
No assurance artifact held on file	**4 of 17 (24%)**	WikiCo, ScribeCo, WriteCo and WhiteboardCo. Three of them *publish* a SOC 2; Cypher Group Inc. simply never obtained one. StatusCo, still onboarding, is not counted. **The vendor having it is not the same as us holding it.**
Discovered outside any procurement process	**2**	ScribeCo and WriteCo — both AI processors of Confidential text. → **VR-005**, **VR-006**
Vendors at inherent **Critical** (15–25)	**2**	CodeCo (15) and ScribeCo (16).
Vendors at inherent **High** (10–14)	**7**	
Aggregate inherent vendor risk	**159** across 17 vendors, mean **9.35**	Recorded as the baseline; Part 6 tracks it.
Tier 1 vendors failing assessment	**1 of 7**	ChatCo. Part 5.1.

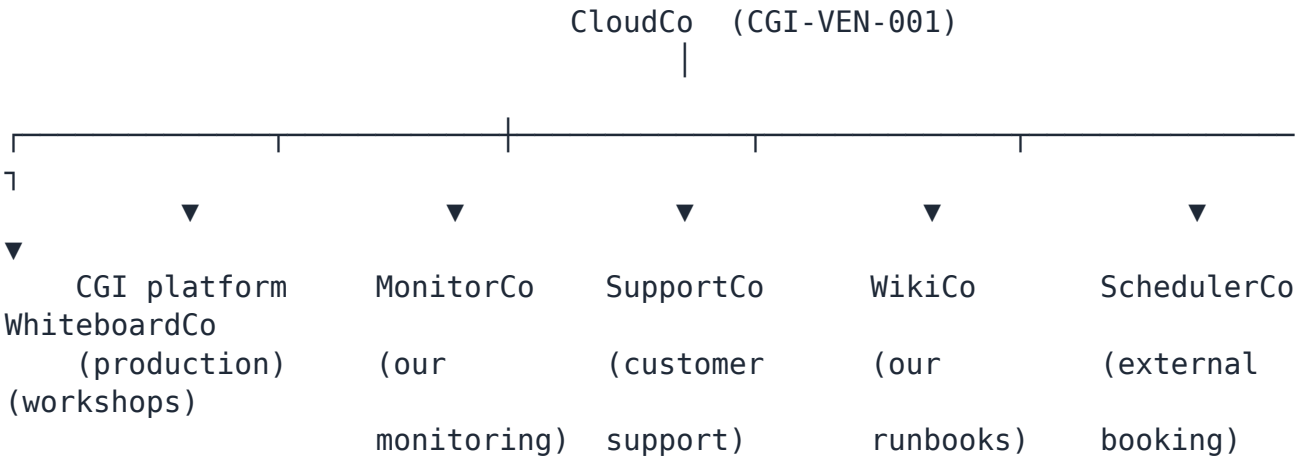
The three findings a CEO needs from this table:

1. **Six vendors have no executed Article 28 contract, and four of them already hold Confidential data.** That is not a risk that might happen. It is a regulatory non-conformity that exists right now, and it would be found by any enterprise customer's own vendor assessment of Cypher Group Inc. — which is the mirror-image point this whole programme eventually earns back.

2. **Two AI vendors are ingesting customer conversations and typed text under no terms at all.** Nobody decided this. It arrived through an expense claim.
3. **The estate was 3.4 times larger than the architecture suggested.** Any organisation that has never done this exercise should assume the same multiple.

2.5 Concentration analysis — the risk that hides behind a vendor list

A vendor list read row by row shows seventeen independent relationships. Read as a dependency graph it shows something else. **Several of the vendors above are themselves hosted on the same underlying cloud provider as the Cypher Group Inc. platform.**



The second-order consequence, which is the whole point of drawing it: a regional failure at that one provider removes the platform, **the monitoring that would detect it**, **the ticketing system customers would use to report it**, and **the runbooks describing what to do** — simultaneously. Resilience purchased by using five different vendors is not resilience if all five sit on the same substrate as the platform.

This is why **REC-14's status page must not be hosted on the same provider as the platform** (CGI-VEN-017 is deliberately not), why the CGI-POL-005 tabletop in REC-12 must nominate an **out-of-band incident channel**, and why this becomes risk **VR-002**.

> **Interview line:** *"A vendor list is a table. A vendor programme is a dependency graph. The table tells you who you pay; the graph tells you what dies together."*

2.6 How vendor findings map back to CGI-RSK-001

The method requires every vendor finding either to tie to an existing risk or to be declared new. Applying the **"would the existing risk's controls have prevented this?"** test from §1.7:

Vendor finding	Existing CGI-RSK-001 risk it touches	Would that risk's controls have caught it?	Verdict
OfficeCo is the identity provider; a compromise is estate-wide	**R-001** credential compromise	Yes — CGI-POL-002 MFA controls apply directly	**New route.** Update R-001 likelihood at v1.1
CodeCo holds all source code and CI secrets	**R-004** production API authorisation flaw	Yes — this is the same code path CG-02 already describes	**New route.** No new risk
CloudCo misconfiguration on the Cypher Group Inc. side	**R-005** CloudCo misconfiguration	Yes — R-005 *is* this risk	**Already covered.** Confirms CG-03
SupportCo attachments may contain customer data	**R-003** insider exfiltration	Partly — but the actor is a support agent, not a leaver	**New route.** Update R-003 scope
No DPA with five vendors	none	**No — no control in the register addresses contracts at all**	**NEW — VR-001**

Vendor finding	Existing CGI-RSK-001 risk it touches	Would that risk's controls have caught it?	Verdict
Shared-substrate correlated failure	none	No	**NEW — VR-002**
Undisclosed fourth-party transfer	R-003 superficially resembles it	**No — CGI-POL-003 §4.5.2 four-hour leaver revocation is inert against a vendor API sync**	**NEW — VR-003**
Vendor-side breach of our data	none	No	**NEW — VR-004**
Shadow IT procurement	none	No	**NEW — VR-005**
AI training and human review of our content	none	No	**NEW — VR-006**
No tested exit from a Tier 1 vendor	none	No	**NEW — VR-007**
Vendor accounts surviving offboarding	**R-003**	**Partly — the SLA exists but cannot technically be met on non-federated vendors**	**Realises R-003 through a route its own control cannot reach — recorded separately as VR-008**
Assurance evidence going stale	none	No	**NEW — VR-009**

Part 3 — Tiering model

3.1 The rule, stated before anything was scored

A tiering model that is written after the tiers are assigned is decoration. This one was published first and then applied mechanically; every tier in Part 2 is reproducible from it, and the workbook recomputes the factor totals as live formulas so that changing an input changes the answer.

STEP 1 — score four factors, each 0 to 3.

Factor	0	1	2	3
D — Data exposure (highest CGI-POL-004 tier the vendor can reach)	Public	Internal	Confidential	Restricted
A — Availability dependency	No operational effect	Internal inconvenience	Major internal disruption	Customer-facing platform outage
C — Connectivity / privilege	No system access	Read-only integration	Read-write integration or SSO	Production infrastructure or source-code access
R — Replaceability	Under 1 business day	Under 1 week	Under 1 month	Over 1 month or contractual lock-in

STEP 2 — apply the mandatory escalation triggers *before* looking at the total. A trigger overrides the score. This is what stops a low arithmetic total hiding a vendor that can end the company.

Trigger	Condition	Effect
T1-a	Processes or can access data classified **Restricted** under CGI-POL-004	**Forces Tier 1**
T1-b	Holds or can access **production customer data**	**Forces Tier 1**
T1-c	Has write access to **production infrastructure or source code**	**Forces Tier 1**
T1-d	Failure causes a **customer-facing outage** of the platform	**Forces Tier 1**
T1-e	Is **named to customers as a sub-processor** in the Cypher Group Inc. customer DPA	**Forces Tier 1**
T2-f	Processes Cypher Group Inc. or customer content through an **automated or AI system that may retain, review or train on that content** (CGI-POL-001 §4.5)	**Forces minimum Tier 2**

STEP 3 — where no trigger fires, the factor total decides.

Tier	Name	Factor total	Assessment depth	Evidence standard	Approval authority	Review cadence	Onboarding SLA	Exit plan
1	**Critical**	**≥ 8**, or any T1 trigger	Full **74-question** VSQ + assurance artifact review including opinion, exceptions, **CUECs**, **CSOCs** and sub-service method + DPA review + data-flow review	**Independent attestation mandatory.** A self-assessment is never sufficient	Chief Executive Officer	**12 months** and on material change	15 business days	Documented and reviewed annually
2	**Important**	**4 – 7**, or trigger T2-f	**VSQ Lite** — the 24 risk-weight-5 questions — plus assurance artifact on file and DPA review	Independent attestation preferred; self-assessment accepted with **written** justification	Chief Technology Officer	**18 months**	7 business days	Documented
3	**Limited**	**≤ 3**	Inventory entry, **6-question attestation**, DPA confirmation	Self-assessment accepted	Business owner	**24 months** or on renewal	2 business days	Not required

3.2 Why these thresholds, and not others

- **Why escalation triggers at all, rather than a pure score?** Because a purely additive model lets a vendor with catastrophic data exposure but easy replaceability average its way into Tier 2. **Catastrophic exposure is not something you average.** The five T1 triggers are the five conditions under which the consequence of failure is unacceptable regardless of every other factor.
- **Why is T2-f (AI processing) a trigger at all?** Because the factor model measures *access*, and an AI processor's risk is not about access — it is about **retention, human review and model training after access is legitimately granted.** WriteCo scores **3** on the four factors, which would place it in Tier 3, and it reads Confidential text typed into every web field the company uses. ScribeCo scores **3** and holds full audio of customer calls. **The arithmetic was wrong for both, so the model carries a rule that corrects it.** Stating that openly is stronger than quietly overriding the score.
- **Why 12 / 18 / 24 months and not annual for everything?** Because an annual review of 17 vendors is 17 reviews a year for a company with no dedicated security staff, and a cadence that is not met produces worse evidence than a cadence that is honest. Tier 1 is seven reviews a year. That is achievable, so it will be evidenced, and **evidence is what moves maturity 2 to 3** (see §GV.SC).
- **Why does the CEO approve Tier 1?** Because Tier 1 is defined as "failure is customer-visible or data-loss", which is a business decision, not a technical one. It also creates the leadership touchpoint CGI-GAP-001 GAP-005 found missing, at no extra meeting cost.
- **Why an onboarding SLA?** Because the single largest cause of shadow IT is a security process slower than the business need. **VR-005 is prevented by the SLA, not by the policy.** A 15-day Tier 1 commitment is the price of being allowed to say no to the two-day workaround.

3.3 Every tier, reproduced from the model

Also available as **`data/04-tiering-model.csv`**.

Vendor ID	Vendor	D Data	A Availability	C Connectivity	R Replaceability	Total	Escalation trigger(s) fired	Tier
CGI-VEN-001	CloudCo	3	3	3	3	**12**	T1-a, T1-b, T1-c, T1-d, T1-e	**1**
CGI-VEN-002	CodeCo	2	2	3	3	**10**	T1-c, T1-e	**1**
CGI-VEN-003	OfficeCo	2	3	2	3	**10**	T1-d, T1-e	**1**
CGI-VEN-004	ChatCo	2	2	2	2	**8**	T1-e	**1**
CGI-VEN-005	PaymentsCo	3	2	1	2	**8**	T1-a, T1-e	**1**
CGI-VEN-006	LoginCo	2	3	2	3	**10**	T1-b, T1-d, T1-e	**1**
CGI-VEN-007	MonitorCo	2	1	3	2	**8**	T1-b, T1-c	**1**
CGI-VEN-008	CRMCo	2	1	1	2	**6**	-	**2**
CGI-VEN-009	SupportCo	2	2	1	1	**6**	-	**2**
CGI-VEN-010	HRCo	2	1	1	2	**6**	-	**2**
CGI-VEN-011	WikiCo	2	1	0	1	**4**	-	**2**
CGI-VEN-012	ScribeCo	2	0	1	0	**3**	T2-f	**2**
CGI-VEN-013	WriteCo	2	0	1	0	**3**	T2-f	**2**
CGI-VEN-014	DesignCo	1	1	0	1	**3**	-	**3**
CGI-VEN-015	SchedulerCo	2	0	1	0	**3**	-	**3**
CGI-VEN-016	WhiteboardCo	1	0	0	0	**1**	-	**3**
CGI-VEN-017	StatusCo	0	1	0	0	**1**	-	**3**

Two results in this table are worth pointing at in an interview:

- **PaymentsCo (CGI-VEN-005): Tier 1, inherent risk only 8 — Medium.** Tier 1 because it touches Restricted data (T1-a) and is a named sub-processor (T1-e). Medium risk because the provider is mature and **AVD-001 already removed cardholder numbers from scope entirely.** *Tier and risk score are different measurements and a good programme keeps both.* A vendor can deserve maximum scrutiny and still be a modest risk — that is the scrutiny working.
- **WriteCo (CGI-VEN-013): factor total 3, tier 2.** Escalated by T2-f. The model is shown overriding its own arithmetic, in writing, with the reason attached.

Part 4 — Vendor security questionnaire

CGI-TPR-002 · 74 questions · 16 domains · dual-mapped to ISO/IEC 27001:2022 Annex A and NIST CSF 2.0.

4.1 How the questionnaire is designed to be used

Four design decisions, each of which is defensible in an interview:

1. **Every question carries an evidence requirement, not just a response type.** A questionnaire that collects answers collects assertions. The **Evidence Required** column is what converts an assertion into something testable, and it is the column most published questionnaires omit.
2. **Every question carries a risk weight of 1 to 5,** so a scored assessment is arithmetic rather than impression. **Weighted deduction = the full weight for every *Not Met*, plus half the weight for every *Partial*. Not**

Applicable questions are removed from the maximum, so a vendor is never penalised for a question that does not apply to its service model.

3. **The tier subsets are mechanical, not curated.** The **Tier 2 Lite set is exactly the 24 questions carrying risk weight 5** — no human chose which to drop, so the rule can be published and audited. The **Tier 3 attestation is a fixed six questions**: VQ-12, VQ-27, VQ-28, VQ-51, VQ-68, VQ-73 — assurance, contract, residency, notification, AI training and deletion. Those six are the minimum any organisation should know about any vendor holding any of its data.
4. **Dual mapping is not decoration.** The ISO column makes this questionnaire the evidence base for Project 5's Statement of Applicability. The CSF column ties every vendor answer back to the Category it affects in CGI-GAP-001, so a failed question is traceable to a maturity score.

4.2 Domains, and why these sixteen

#	Domain	Qs	Why it is here
1	Governance and Security Programme	5	Does a programme exist, with an owner and a review cycle — the vendor's own GV.PO and GV.RR
2	Risk Management	4	Including whether the vendor assesses **its own** suppliers — the fourth-party question in disguise
3	Policies, Compliance and Certifications	5	The artifact questions, including **scope**, **method** and **exceptions**, which is where assurance is actually read
4	Identity and Access Management	6	Mirrors CGI-POL-002 and CGI-POL-003; VQ-19 and VQ-20 exist specifically to test whether the CGI-POL-003 §4.5.2 four-hour SLA is technically achievable at this vendor
5	Data Protection and Encryption	6	Confidentiality at rest and in transit, tenancy separation, retention
6	Data Privacy and GDPR	6	Article 28 contract, residency, Article 46 transfers, data subject rights, Article 30 records
7	Sub-processors and Fourth Parties	4	The layer most questionnaires stop short of. Weight 5 on the list and on the notice period
8	Secure Development and Change Management	5	Mirrors CG-02 and CGI-POL-007; asks the vendor what Cypher Group Inc. itself cannot yet answer
9	Vulnerability and Patch Management	4	Mirrors CG-02 and CGI-POL-008
10	Logging, Monitoring and Detection	4	VQ-48 is the one that matters: **can we get audit logs of our own tenant**, without which RS.AN is impossible
11	Incident Response and Breach Notification	5	VQ-51's notification hours is the control that makes CGI-POL-005 §5.6.3's 72-hour GDPR duty achievable
12	Business Continuity, Backup and Resilience	5	RTO, RPO, tested restore, and **exportability** — the difference between a backup and a recovery
13	Personnel Security and Awareness	4	The vendor's own PR.AT
14	Physical and Environmental Security	3	Short by design: most SaaS vendors carve this out to their hosting provider, and VQ-64 makes them say so
15	**AI and Automated Processing**	4	**All four carry weight 5.** Retention, training, human review and the AI sub-processor chain. This is the domain most 2020-vintage questionnaires do not have, and it is where two of this estate's worst findings came from
16	Contract, Exit and Termination	4	Audit right, insurance, certified deletion, transition assistance — the levers that only exist before signature

4.3 Scoring bands

Weighted score	Verdict	Action
≥ 90% with no weight-5 *Not Met*	**Pass**	Onboard or continue. Record and diary the next review.

Weighted score	Verdict	Action
75 – 89%, or ≥ 90% with one weight-5 *Not Met*	**Pass with conditions**	Onboard with written, dated, owned conditions and a re-check date.
< 75%, or **two or more weight-5 *Not Met***	**Fail**	Remediate within 90 days or exit. No Tier 1 vendor may operate in Fail status beyond one quarter without a CEO-approved, expiring risk acceptance.
Tier 3, low exposure	**Accept with justification**	Tier 3 only. Requires a written justification, a named owner and an expiry date, on the CGI-RSK-001 ACC-001 pattern.

Note the override. The bands are arithmetic, but **two weight-5 failures force a Fail regardless of percentage**. ChatCo scores 65%, so the override is not needed there — but without it a vendor could fail the DPA question and the breach-notification question and still pass on volume of easy answers. A scoring model without a veto is a scoring model that can be gamed by breadth.

4.4 The 74 questions

Paste-ready, with the reviewer columns already present: **`data/04-vendor-security-questionnaire.csv`** Legend: **Wt** = risk weight 1–5 · **T2** = in the Tier 2 Lite set · **T3** = in the Tier 3 attestation set.

1. Governance and Security Programme

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-01	Do you maintain a documented information security programme formally approved by executive management?	Yes/No + document	Approved security policy set with an approval record	**4**	A.5.1, A.5.4	GV.PO		
VQ-02	Is a named individual accountable for information security (CISO or equivalent)? State the role title.	Yes/No + free text	Organisation chart or role description	**3**	A.5.2	GV.RR		
VQ-03	How many staff are dedicated to information security on a full-time basis?	Numeric	Written headcount statement	**2**	A.5.2	GV.RR		
VQ-04	Are security policies reviewed at least annually? State the date of the last review.	Yes/No + date	Dated review or approval record	**3**	A.5.1, A.5.36	GV.PO		
VQ-05	Do you report security performance metrics to executive management at least quarterly?	Yes/No	Redacted sample management report	**2**	A.5.35	GV.OV		

2. Risk Management

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-06	Do you operate a documented information security risk assessment methodology?	Yes/No + document	Methodology document naming the scoring method	**4**	A.5.1	ID.RA		

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-07	When was your last enterprise information security risk assessment completed?	Date	Assessment summary or management report	3	A.5.1	ID.RA		
VQ-08	Is there a documented risk acceptance process with a defined approval authority?	Yes/No	Sample risk acceptance record	3	A.5.4	GV.RM		
VQ-09	Does your risk register include risks arising from your own suppliers?	Yes/No	Redacted register extract	3	A.5.21	GV.SC		

3. Policies, Compliance and Certifications

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-10	Do you hold a current ISO/IEC 27001 certificate issued by an accredited certification body?	Yes/No/NA + upload	Certificate showing certification body and accreditation mark	5	A.5.1, A.5.31	GV.OC	•	
VQ-11	State the exact scope of that certificate, transcribed as written on the certificate itself.	Free text	Certificate scope statement	5	A.5.1, A.5.31	GV.OC	•	
VQ-12	Do you provide a SOC 2 Type II report, and what period does it cover?	Yes/No + date range + upload	Complete report including Section 4 test results	5	A.5.1, A.5.31	GV.OC	•	•
VQ-13	Does that report use the CARVE-OUT or the INCLUSIVE method for sub-service organisations? Name every carved-out sub-service organisation.	Multiple choice + free text	Report Section 3 system description	5	A.5.21, A.5.23	GV.SC	•	
VQ-14	List every exception, qualification or deviation in your most recent report, and its remediation status.	Free text	Report Section 4 plus written remediation plan	5	A.5.36	GV.OV	•	

4. Identity and Access Management

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-15	Is multi-factor authentication enforced for all personnel with access to customer data?	Yes/No	Policy plus configuration evidence	5	A.8.5, A.5.17	PR.AA	•	

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-16	Is phishing-resistant MFA enforced for privileged and administrative accounts?	Yes/No	Configuration evidence	4	A.8.2, A.8.5	PR.AA		
VQ-17	Is access granted on a documented least-privilege, role-based model?	Yes/No + document	Role-based access control model	4	A.5.15, A.5.18	PR.AA		
VQ-18	How frequently are user access rights reviewed? State the date of the last completed review.	Multiple choice + date	Signed and dated access review record	4	A.5.18	PR.AA		
VQ-19	What is your service-level commitment for revoking access on employee termination?	Numeric (hours)	Procedure plus a sample completed revocation record	4	A.5.18, A.6.5	PR.AA		
VQ-20	Do you support SSO (SAML or OIDC) and automated provisioning and deprovisioning (SCIM) for customer administrators?	Yes/No	Product documentation	4	A.5.16	PR.AA		

5. Data Protection and Encryption

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-21	Is customer data encrypted at rest? State the algorithm and key length.	Yes/No + free text	Encryption standard	5	A.8.24	PR.DS	•	
VQ-22	Is customer data encrypted in transit? State the minimum TLS version enforced.	Yes/No + free text	TLS configuration evidence	5	A.8.24	PR.DS	•	
VQ-23	How are encryption keys generated, stored and rotated? Is a customer-managed key option available?	Free text	Key management procedure	3	A.8.24	PR.DS		
VQ-24	Is customer data logically or physically segregated between tenants? Describe the mechanism.	Yes/No + free text	Architecture or multi-tenancy description	5	A.8.22, A.8.31	PR.DS	•	
VQ-25	Do you operate documented data retention and secure deletion schedules?	Yes/No + document	Retention schedule	4	A.8.10	PR.DS		
VQ-26	Do you deploy data loss prevention or egress monitoring on systems holding customer data?	Yes/No	DLP configuration summary	3	A.8.12	PR.DS		

6. Data Privacy and GDPR

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-27	Will you execute our Data Processing Agreement, or provide one satisfying GDPR Article 28(3)?	Yes/No	Executed DPA	5	A.5.34, A.5.20	GV.OC	•	•
VQ-28	In which countries will our data be stored, processed and accessed from, including support access?	Free text	Data residency statement	5	A.5.34	GV.OC	•	•
VQ-29	Where data leaves the EEA, which GDPR Article 46 transfer mechanism applies?	Multiple choice + free text	Standard Contractual Clauses or adequacy reference, plus transfer impact assessment	5	A.5.34	GV.OC	•	
VQ-30	Have you appointed a Data Protection Officer or equivalent? Give the contact route.	Yes/No + free text	Appointment record	2	A.5.34	GV.RR		
VQ-31	Can you support data subject access, rectification and erasure requests, and within what period?	Yes/No + numeric (days)	Data subject request procedure	4	A.5.34	GV.OC		
VQ-32	Do you maintain records of processing activities under GDPR Article 30?	Yes/No	Records of processing extract	3	A.5.34	GV.OC		

7. Sub-processors and Fourth Parties

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-33	Provide your complete current sub-processor list, with the service each performs and its location.	Free text + upload	Published or contractual sub-processor register	5	A.5.19, A.5.21	GV.SC	•	
VQ-34	How much prior notice is given of a new or changed sub-processor, and do we have a right to object?	Numeric (days) + Yes/No	Contract clause	5	A.5.22	GV.SC	•	
VQ-35	Do you security-assess your own sub-processors before engagement? To what standard?	Yes/No + free text	Supplier assessment procedure	4	A.5.19, A.5.21	GV.SC		

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-36	Do you flow down equivalent security and privacy obligations to your sub-processors?	Yes/No	Template sub-processor agreement	4	A.5.20	GV.SC		

8. Secure Development and Change Management

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-37	Do you follow a documented secure development lifecycle?	Yes/No + document	SDLC procedure	4	A.8.25	PR.PS		
VQ-38	Is peer code review mandatory before any merge to a production branch?	Yes/No	Branch protection configuration evidence	4	A.8.28, A.8.32	PR.PS		
VQ-39	Are development, test and production environments separated? Is production data ever used in lower environments?	Yes/No + free text	Environment separation policy	4	A.8.31	PR.PS		
VQ-40	Do you perform static and dynamic application security testing within the pipeline?	Yes/No + free text	Scan configuration and redacted sample output	4	A.8.29	PR.PS		
VQ-41	Do you maintain a software bill of materials and monitor third-party components for known vulnerabilities?	Yes/No	SBOM sample or software composition analysis report	3	A.8.8	PR.PS		

9. Vulnerability and Patch Management

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-42	Do you perform authenticated vulnerability scanning, and at what frequency?	Yes/No + multiple choice	Scan schedule and redacted sample report	4	A.8.8	ID.RA		
VQ-43	State your remediation service levels by severity for Critical, High, Medium and Low findings.	Free text	Vulnerability management policy	4	A.8.8	PR.PS		
VQ-44	Is an independent penetration test performed at least annually? Will you share the executive summary?	Yes/No + date	Executive summary of the most recent test	4	A.8.29	ID.RA		

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-45	Do you operate a coordinated vulnerability disclosure or bug bounty programme?	Yes/No + free text	Published disclosure policy	2	A.5.7	ID.RA		

10. Logging, Monitoring and Detection

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-46	Are security-relevant events logged centrally? For how many months are logs retained?	Yes/No + numeric (months)	Logging standard	4	A.8.15	DE.CM		
VQ-47	Is there 24x7 monitoring and alerting on security events? In-house or outsourced?	Yes/No + free text	Monitoring or SOC description	3	A.8.16	DE.CM		
VQ-48	Can you provide customer-accessible audit logs of administrative activity within our tenant?	Yes/No	Product documentation	4	A.8.15	DE.CM		
VQ-49	Do you alert on anomalous access to customer data, such as bulk export or mass download?	Yes/No + free text	Alerting rule description	3	A.8.16, A.8.12	DE.CM		

11. Incident Response and Breach Notification

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-50	Do you maintain a documented incident response plan? When was it last exercised?	Yes/No + date	Incident response plan plus dated exercise record	5	A.5.24, A.5.26	RS.MA	•	
VQ-51	Within how many hours will you notify us of a security incident affecting our data?	Numeric (hours)	Contractual notification clause	5	A.5.26, A.6.8	RS.CO	•	•
VQ-52	Who is the named security incident contact, and what is the out-of-hours escalation route?	Free text	Contact record with 24x7 route	4	A.5.5	RS.CO		
VQ-53	Have you experienced a reportable security breach in the last 24 months? Describe it and the remediation.	Yes/No + free text	Breach summary and remediation evidence	5	A.5.27	RS.AN	•	
VQ-54	Do you support customer forensic requests and preserve evidence to a defined standard?	Yes/No	Evidence handling and chain-of-custody procedure	3	A.5.28	RS.AN		

12. Business Continuity, Backup and Resilience

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-55	State your contractual availability commitment and your achieved availability over the last 12 months.	Free text	Service level agreement plus uptime report	**4**	A.5.30	PR.IR		
VQ-56	State the documented Recovery Time Objective and Recovery Point Objective for the service we consume.	Free text	Business continuity or disaster recovery plan	**5**	A.5.29, A.5.30	RC.RP	•	
VQ-57	When was the disaster recovery plan last tested, and what was the documented result?	Date + free text	Disaster recovery test report	**5**	A.5.30	RC.RP	•	
VQ-58	Are backups encrypted, and are restores tested at a defined frequency?	Yes/No + multiple choice	Backup policy and a dated restore test record	**4**	A.8.13	RC.RP		
VQ-59	Can we export our complete dataset in a documented, machine-readable format on demand?	Yes/No + free text	Export documentation	**4**	A.5.29	RC.RP		

13. Personnel Security and Awareness

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-60	Are background checks performed on personnel with access to customer data, where lawful?	Yes/No + free text	Screening policy	**3**	A.6.1	PR.AT		
VQ-61	Do all personnel and contractors sign confidentiality agreements?	Yes/No	Template confidentiality clause	**3**	A.6.6	PR.AT		
VQ-62	Is security awareness training mandatory at induction and at least annually? State current completion rate.	Yes/No + numeric (%)	Training completion report	**3**	A.6.3	PR.AT		
VQ-63	Do you run phishing simulations? State the click rate recorded in the most recent exercise.	Yes/No + free text	Simulation results	**2**	A.6.3	PR.AT		

14. Physical and Environmental Security

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-64	Where is customer data physically hosted, and is it in your own facilities or a sub-service provider's?	Free text	Facility description or provider attestation	3	A.7.1	PR.IR		
VQ-65	Is physical access to hosting facilities controlled, logged and periodically reviewed?	Yes/No	Facility attestation or sub-service provider report	3	A.7.2, A.7.4	PR.IR		
VQ-66	Are storage media securely destroyed at end of life to a recognised standard?	Yes/No + free text	Sample certificate of destruction	2	A.7.10, A.7.14	PR.DS		

15. AI and Automated Processing

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-67	Does the service process our data using AI or machine learning, including for features we have not explicitly enabled?	Yes/No + free text	Product and data-flow documentation	5	A.5.34, A.8.25	GV.SC	•	
VQ-68	Is our data used to train, fine-tune or evaluate any model, whether yours or a third party's?	Yes/No	Contractual prohibition or signed written confirmation	5	A.5.20, A.5.34	GV.SC	•	•
VQ-69	Is our data exposed to human review by your staff or contractors for quality, safety or model improvement?	Yes/No + free text	Human review policy and the access controls around it	5	A.5.34, A.5.20	GV.SC	•	
VQ-70	Name every AI sub-processor or model provider in the data path, and the retention period at each.	Free text	Sub-processor register entry covering AI providers	5	A.5.21	GV.SC	•	

16. Contract, Exit and Termination

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-71	Will you accept a contractual right of audit, or an annual assurance review in place of one?	Yes/No + free text	Contract clause	3	A.5.20, A.5.22	GV.SC		
VQ-72	Do you carry cyber liability insurance? State the limit of indemnity.	Yes/No + free text	Certificate of insurance	3	A.5.20	GV.SC		

ID	Question	Response Type	Evidence Required	Wt	ISO 27001:2022 Annex A	CSF 2.0	T2	T3
VQ-73	On termination, within how many days is our data deleted, and will you certify the deletion in writing?	Numeric (days) + Yes/No	Template certificate of deletion	**5**	A.8.10, A.5.20	GV.SC	•	•
VQ-74	Do you provide transition assistance on exit, and is the scope contractually defined?	Yes/No + free text	Contract clause	**3**	A.5.20	GV.SC		

Part 5 — Three completed vendor assessments

Three vendors, three outcomes, one method. Summary sheet: **`04_Assessments`** in the workbook.

Assessment	Vendor	Tier	Applied	Met / Partial / Not Met / N/A	Deduction	Max	Score	Findings	Inherent	Residual	Decision
VRA-2026-002	ChatCo (CGI-VEN-004)	1	74	41 / 14 / 17 / 2	98.5	282	**65%**	9 (5 Crit/High)	12 High	**12 High**	🔴 **FAIL — remediate or exit**
VRA-2026-001	CloudCo (CGI-VEN-001)	1	74	62 / 9 / 3 / 0	32	288	**89%**	4 (1 High)	10 High	8 Medium	🟠 **PASS WITH CONDITIONS**
VRA-2026-003	Scheduler Co (CGI-VEN-015)	3	6	5 / 1 / 0 / 0	2.5	30	**92%**	1 observation	4 Low	4 Low	🟢 **ACCEPTED — documented justification**

5.1 VRA-2026-002 — ChatCo (CGI-VEN-004) · Tier 1 · FAIL

Field	Value
Assessment ID	VRA-2026-002
Vendor	ChatCo — CGI-VEN-004
Service	Internal communications, the incident channel, and three shared channels with customers
Business owner	IT Operations Manager
Tier	**1** — trigger T1-e (named sub-processor); factor total 8
Assessment depth	Full 74-question VSQ, assurance artifact review, DPA review
Assessor / Approver	O.S / Jerry Olugboye
Date	15 September 2026
Weighted score	**65%** (98.5 deducted from a maximum of 282, net of 2 N/A)
Weight-5 questions Not Met	**7** — VQ-27, VQ-29, VQ-34, VQ-51, VQ-67, VQ-68, VQ-73 (against a Fail threshold of 2)
Inherent vendor risk	**12 — High** (L3 × I4)
Residual vendor risk	**12 — High. No reduction. That is the finding.**

Field	Value
Post-remediation target	**6 — Medium** (L2 × I3)
Decision	**FAIL — REMEDIATE OR EXIT by 15 December 2026**

Reviewer assessment

ChatCo is the most heavily used system in the company after OfficeCo, carries the CGI-POL-005 incident channel, and has three shared channels through which customers post directly. It is also the only Tier 1 vendor in the estate operating with **no executed Data Processing Agreement of any kind**.

The failure here is **not that ChatCo is insecure**. ChatCo's own control environment is strong and its published assurance is real. The failure is entirely on Cypher Group Inc.'s side of the relationship: nobody ever executed the contract, nobody obtained a current report, nobody checked whether the plan in use could technically support the access-revocation SLA Cypher Group Inc. has written into its own policy, and nobody read the AI feature terms. **Every one of the nine findings below is a Cypher Group Inc. governance failure, not a ChatCo security failure.** That distinction matters because it determines the remediation: four of the nine are closed by signing a document, and two by changing a plan.

The residual risk is scored **unchanged from inherent at 12, High**, because **no Cypher Group Inc. control currently reduces it.** Scoring a reduction here because the vendor is reputable would be exactly the "your vendor's certification is your vendor's control" error this programme exists to correct.

Findings

ID	Sev	Finding	Question(s)	Evidence	Risk if unaddressed
F-001	🔴 **Critical**	**No executed DPA.** Confidential data including incidental customer personal data is processed by a US-hosted processor with no Article 28 contract, no documented processing instructions, no Article 32 security obligation and no Article 46 transfer mechanism recorded.	VQ-27, VQ-28, VQ-29	No DPA on file; hosting region confirmed United States	A present-tense GDPR Article 28 non-conformity. Any enterprise customer assessing Cypher Group Inc. would find it, and a supervisory authority would treat it as a failure of controller diligence. → **VR-001**
F-002	🔴 **Critical**	**No contractual breach-notification commitment and no named incident contact.** There is no agreed number of hours within which Cypher Group Inc. would be told of an incident, and no out-of-hours route.	VQ-51, VQ-52	No contract; support portal only	**CGI-POL-005 §5.6.3 commits Cypher Group Inc. to notifying a supervisory authority within 72 hours of awareness. Without a vendor notification clause, "awareness" is outside the company's control.** The most consequential written commitment in the policy pack is unenforceable against this vendor. → **VR-004**

ID	Sev	Finding	Question(s)	Evidence	Risk if unaddressed
F-003	🟠 **High**	**No SCIM or automated deprovisioning on the current plan.** Account removal is manual and performed by a workspace admin.	VQ-19, VQ-20	Plan feature matrix; no SSO federation configured	**CGI-POL-003 §4.5.2 requires revocation within four hours of a leaver event. On this vendor that SLA is not technically achievable**, so a control Cypher Group Inc. has published and relies upon in R-003's treatment does not operate here. → **VR-008**
F-004	🟠 **High**	**AI features process message content; training is not contractually prohibited and human review is not excluded.**	VQ-67, VQ-68, VQ-69	No contract; vendor terms not reviewed at procurement	Message content includes security discussion, pasted credentials and customer detail. With no contractual prohibition there is no basis to assert to a customer where their content has been, and no route to recall it. → **VR-006**
F-005	🟠 **High**	**Unlimited message retention and no deletion-on-termination obligation or certification.**	VQ-25, VQ-73	Workspace retention setting = unlimited	Every credential, screenshot and customer record ever pasted persists indefinitely, with no contractual deletion duty on exit. **This is a right-of-bang control: it does not make a breach likelier, it makes every breach maximally large.**
F-006	🟡 Medium	**Assurance artifact stale.** The SOC 2 Type II held covers a period ended 30 Nov 2025 — 9.5 months before this assessment — with no bridge letter.	VQ-12	Report on file, period end date	The report describes a period that ended before three of this estate's current configurations existed. Assurance is asserted that no current evidence supports. → **VR-009**
F-007	🟡 Medium	**Carve-out method; carved-out sub-service organisations not enumerated and the CSOC list not reviewed.**	VQ-13, VQ-33	Report Section 3	Fourth-party exposure is invisible. The opinion held is narrower than it appears. → **VR-003**
F-008	🟡 Medium	**No customer-accessible audit log of administrative activity on the current plan.**	VQ-48	Plan feature matrix	Cypher Group Inc. could not establish who did what in its own workspace during an investigation. Directly blocks **RS.AN** (CGI-GAP-001 GAP-018, currently 1).
F-009	🟢 Low	**No contractual right of audit;** attestation offered in lieu.	VQ-71	Standard terms	Accepted as normal commercial practice for a vendor of this size. Recorded, not remediated.

Remediation plan

Action	Closes	Owner (Job Title)	Due	Cost	Verification
R1 Execute the vendor's standard DPA including SCCs, and record the executed copy in the inventory	F-001	Chief Technology Officer	**15 Oct 2026**	Nil	Executed DPA on file, inventory column J updated to Y + date

Action	Closes	Owner (Job Title)	Due	Cost	Verification
R2 Obtain a written incident-notification commitment of **24 hours or less** and a named security contact with an out-of-hours route	F-002	Chief Technology Officer	**15 Oct 2026**	Nil	Clause in the DPA or an addendum; contact recorded in the inventory
R3 Upgrade to a plan supporting **SSO federation and SCIM**, then federate the workspace to OfficeCo	F-003	IT Operations Manager	**15 Nov 2026**	~USD 3,600 / yr uplift	One test leaver revoked and evidenced inside four hours
R4 Disable AI features that process message content until a contractual prohibition on training and human review is in place	F-004	Chief Technology Officer	**01 Oct 2026**	Nil	Admin setting screenshot; clause in the executed DPA
R5 Set message retention to **12 months** for general channels and **24 months** for the incident channel, aligned to the log-retention standard REC-07 will establish	F-005	IT Operations Manager	**15 Oct 2026**	Nil	Retention policy screenshot
R6 Obtain the current-period SOC 2 Type II, or a bridge letter, and diary the next report date	F-006, F-007	Chief Technology Officer	**15 Nov 2026**	Nil	Report on file; sub-service organisations enumerated; CSOCs reviewed and assigned
R7 Enable the audit-log capability delivered by the R3 plan upgrade and route it to the destination REC-07 creates	F-008	IT Operations Manager	**15 Dec 2026**	Included in R3	Sample export retained
R8 If R1, R2 and R4 are not complete by **15 Nov 2026**, open a migration assessment for an EU-hosted alternative and cease posting Confidential data to the platform in the interim	all	Chief Executive Officer	**15 Nov 2026** gate	TBD	CEO decision recorded

Total remediation cost: approximately USD 3,600 per year. Six of the eight actions cost nothing. This is the honest headline: **a Critical vendor finding at a company this size is usually a governance failure with a near-zero price tag, not a technology problem with a large one.**

Re-assessment: 15 December 2026. ChatCo may not operate in Fail status beyond one quarter without a CEO-approved, expiring risk acceptance on the CGI-RSK-001 **ACC-001** pattern.

5.2 VRA-2026-001 — CloudCo (CGI-VEN-001) · Tier 1 · PASS WITH CONDITIONS

Field	Value
Assessment ID	VRA-2026-001
Vendor	CloudCo — CGI-VEN-001
Service	Cloud hosting and infrastructure for the production platform
Business owner	Chief Technology Officer
Tier	**1** — triggers T1-a, T1-b, T1-c, T1-d, T1-e (all five); factor total 12, the maximum
Assessor / Approver	O.S / Jerry Olugboye
Date	15 September 2026
Weighted score	**89%** (32 deducted from a maximum of 288)
Weight-5 questions Not Met	**0**
Inherent vendor risk	**10 — High** (L2 × I5) — low likelihood, maximum impact

Field	Value
Residual vendor risk	**8 — Medium** (L2 × I4)
Decision	**PASS WITH CONDITIONS** — four conditions, all due 15 December 2026

Reviewer assessment

CloudCo holds current SOC 2 Type II, ISO/IEC 27001, 27017 and 27018, publishes a sub-processor list, and provides a GDPR DPA incorporating Standard Contractual Clauses. Assessed as a provider, it is the strongest vendor in the estate by a wide margin, and **not one of the four conditions below concerns an CloudCo control.**

All four are Cypher Group Inc. actions. Three of them come from a single place: the **Complementary User Entity Controls** listed near the back of the SOC 2 report. Those are the controls the auditor **assumed the customer was performing** when forming the opinion. Cypher Group Inc. is not performing them, which means the unqualified opinion on file — the document that would be shown to an enterprise buyer as evidence of a secure platform — **does not extend to Cypher Group Inc.'s actual usage.**

This is the entire thesis of Part 1.5 demonstrated on the most certified vendor available. It also reconciles exactly with CGI-GAP-001: **R-005 remains at residual 12, High, precisely because CG-03 — no cloud configuration baseline, no drift detection — sits on Cypher Group Inc.'s side of the shared responsibility boundary, where no CloudCo certificate reaches.**

The residual reduces from 10 to 8 because independent, in-period, correctly scoped assurance **is** a real control and it does reduce impact — but it does not reduce it to Low while four assumed controls are unassigned.

Findings

ID	Sev	Finding	Question(s)	Risk if unaddressed
F-010	🟠 **High**	**Four Complementary User Entity Controls are unaccepted and unassigned.** The report assumes the customer (a) enables organisation-wide CloudTrail with log file validation, (b) enforces MFA on the root account and restricts its use, (c) applies least-privilege IAM with periodic review, and (d) manages encryption for customer-controlled data. **None is evidenced at Cypher Group Inc.**	VQ-13, VQ-15, VQ-16, VQ-46, VQ-48	**The opinion in the report does not cover Cypher Group Inc.'s use of the service.** Presenting it to a customer as assurance over the platform would be materially misleading. Maps directly to **CG-03**, and to REC-01, REC-02, REC-07 and REC-11.
F-011	🟡 Medium	**Carve-out method; the CSOC list has never been reconciled** against Cypher Group Inc.'s actual architecture.	VQ-13	Fourth-party controls are assumed rather than confirmed.
F-012	🟡 Medium	**The sub-processor change feed is published; Cypher Group Inc. is not subscribed** and has never reconciled the list. There is therefore no practical exercise of the right to object.	VQ-33, VQ-34	A new sub-processor could enter the data path with formally valid notice that nobody at Cypher Group Inc. reads. → **VR-003**
F-013	🟡 Medium	**No Cypher Group Inc. RTO or RPO is declared, no restore has been tested, and the data-export path has never been exercised.** The provider's availability SLA exists; the customer's recovery capability does not.	VQ-56, VQ-57, VQ-59	Confirms **CGI-GAP-001 GAP-021 (RC.RP = 1)** from the vendor side. An untested backup is an assumption. Closed by **REC-03**. → **VR-007**

Conditions of the pass

#	Condition	Owner (Job Title)	Due	Evidence required
C1	Formally accept the four CUECs, assign each an owner, and record the acceptance in the inventory against CGI-VEN-001	Chief Technology Officer	15 Dec 2026	Signed CUEC acceptance record with four named owners
C2	Subscribe to the sub-processor change feed and perform a first reconciliation	Chief Technology Officer	15 Dec 2026	Dated reconciliation record
C3	Either purchase a support tier providing a named incident escalation route, or record a CEO-approved written acceptance of the limitation	Chief Executive Officer	15 Dec 2026	Support contract, or an expiring acceptance record
C4	Declare RTO and RPO and evidence one successful restore test to a clean environment (**this is REC-03 — do not run it twice**)	IT Operations Manager	15 Dec 2026	Dated restore test report and an approved CGI-POL-006

If C1 is not met, the conditional pass lapses to Fail at the 15 December 2026 checkpoint, because an unassigned CUEC means the assurance on file is not assurance over this company.

> **Interview line, and the best one in this document:** *"CloudCo passed with conditions, and every single condition was ours. The report was fine. Our use of the report was the finding."*

5.3 VRA-2026-003 — SchedulerCo (CGI-VEN-015) · Tier 3 · ACCEPTED

Field	Value
Assessment ID	VRA-2026-003
Vendor	SchedulerCo — CGI-VEN-015
Service	External meeting scheduling
Business owner	Head of Customer Success
Tier	**3** — factor total 3 (D2 A0 C1 R0); **no escalation trigger fired**
Assessment depth	Tier 3 attestation — 6 questions (VQ-12, VQ-27, VQ-28, VQ-51, VQ-68, VQ-73)
Assessor / Approver	O.S / Head of Customer Success
Date	15 September 2026
Weighted score	**92%** (2.5 deducted from a maximum of 30)
Inherent vendor risk	**4 — Low** (L2 × I2)
Residual vendor risk	**4 — Low**
Decision	**ACCEPTED with documented justification — acceptance record ACC-V01**

Reviewer assessment

SchedulerCo holds invitee name, email address and a meeting subject line. It holds no customer account data, no Restricted data, has no production access, and its unavailability would cause no customer-facing outage. Scheduling would revert to email within one business day.

The correct professional answer here is a light-touch acceptance, and saying so is a skill. A vendor programme that applies Tier 1 depth to a scheduling tool is not rigorous, it is unfunded — it will consume the attention ChatCo and CloudCo needed, and within two quarters nobody will be running it at all. Tiering is what makes it legitimate to spend twenty minutes here and two days on CloudCo, and the legitimacy comes from the rule being published *before* the decision, not from the decision feeling reasonable.

The attestation returned a SOC 2 Type II in period, an executed DPA with Standard Contractual Clauses, a contractual breach-notification commitment, a written confirmation that customer data is not used for model training, and a 30-day deletion-on-termination commitment. One partial, recorded below.

Finding

ID	Sev	Observation	Question	Treatment
O-001	⚪ Observation	Data is processed in the United States and **no EU data-residency option is available on any plan.** Transfers rest on Standard Contractual Clauses with no transfer impact assessment performed by Cypher Group Inc.	VQ-28	**Accepted.** The data is invitee name, email and subject line, volunteered by the invitee at the point of booking. A compensating configuration change is applied: booking pages must not request free-text detail beyond a subject line, so no Confidential context can be entered into the tool.

Acceptance record ACC-V01

Field	Value
Acceptance ID	**ACC-V01**
What is accepted	US processing of invitee name, email and subject line under SCCs, with no EU residency option and no transfer impact assessment
Justification	No Restricted data · no customer account data · no production access · no availability dependency · replaceable within one business day · SOC 2 Type II held and in period · DPA executed with SCCs · residual risk 4, Low
Compensating control	Booking pages restricted to a subject line only; no free-text fields enabled
Owner (Job Title)	Head of Customer Success
Approved by	Head of Customer Success (Tier 3 approval authority per Part 3)
Date	15 September 2026
Expiry	**15 September 2028**, with the Tier 3 review — or earlier on any change of service, data type or plan

> **One honest limitation, recorded rather than hidden.** This acceptance is made against a risk appetite Cypher Group Inc. **has not yet declared** — the same weakness CGI-GAP-001 **GAP-002** identified in the approval of **ACC-001**, and which **REC-13** exists to close. Until the CEO-approved appetite statement lands, every acceptance in this programme rests on the assessor's judgement rather than on a stated tolerance. That does not make the acceptance wrong; it makes it **personal rather than institutional**, and it is recorded here so that the next reviewer knows.

Part 6 — Vendor risk register addendum

For merge into CGI-RSK-001 as v1.1. Same method, same scales, same thresholds, same column set as v1.0 — **NIST SP 800-30 Rev. 1 semi-quantitative 5 × 5**, thresholds **Low 1–4 · Medium 5–9 · High 10–14 · Critical 15–25**. Nine risks, **VR-001 to VR-009**, continuing the register rather than replacing it.

Full 19-column grid: **`data/04-vendor-risk-register-addendum.csv`** · workbook sheet **`05_Risk_Addendum`**.

6.1 The nine risks

Risk ID	Risk Title	Owner (Job Title)	Inh. L	Inh. I	Inherent	Res. L	Res. I	Residual	Strategy	New or Realises
VR-001	Personal data processed by a sub-processor under no Article 28 contract	Chief Technology Officer	4	4	**16** Critical	2	4	**8** Medium	Mitigate	**NEW**

Risk ID	Risk Title	Owner (Job Title)	Inh. L	Inh. I	Inherent	Res. L	Res. I	Residual	Strategy	New or Realises
VR-002	Concentration risk - correlated failure of nominally independent vendors	Chief Technology Officer	2	5	**10** High	2	4	**8** Medium	Mitigate	**NEW**
VR-003	Undisclosed fourth party receives customer personal data through a vendor integration	Chief Technology Officer	3	4	**12** High	2	4	**8** Medium	Mitigate	**NEW**
VR-004	Vendor breach exposes CGI customer data held outside the CGI environment	Chief Technology Officer	3	5	**15** Critical	3	4	**12** High	Mitigate	**NEW**
VR-005	Shadow IT - business units procure SaaS with no security review	Finance Manager	4	3	**12** High	3	3	**9** Medium	Mitigate	**NEW**
VR-006	Third-party AI system retains, reviews or trains on CGI and customer content	Chief Technology Officer	4	4	**16** Critical	3	3	**9** Medium	Mitigate	**NEW**
VR-007	Vendor lock-in - no tested exit capability from a Tier 1 provider	Chief Executive Officer	3	4	**12** High	3	3	**9** Medium	Mitigate	**NEW**
VR-008	Vendor accounts survive employee offboarding, defeating the four-hour revocation SLA	IT Operations Manager	4	4	**16** Critical	3	3	**9** Medium	Mitigate	Realises R-003

Risk ID	Risk Title	Owner (Job Title)	Inh. L	Inh. I	Inherent	Res. L	Res. I	Residual	Strategy	New or Realises
VR-009	Assurance decay - vendor evidence expires and is never re-collected	Chief Technology Officer	4	3	**12** High	2	3	**6** Medium	Mitigate	**NEW**

Aggregate inherent 121, mean 13.44 → aggregate residual 78, mean 8.67. A 36% reduction.

> **Why 36% and not the 52% the policy pack achieved in CGI-RSK-001 — and why the smaller number is the honest one.** In v1.0, most controls credited for the reduction were **already written and approved**. Here, most of the controls are **delivered by this document and not yet operating**: the onboarding gate has blocked nothing yet, the reconciliation has run zero times, the clause checklist has been applied to one contract. **Claiming a 52% reduction on controls with no execution record would be the exact error CGI-GAP-001 §2.2 exists to prevent** — and it is the same error as scoring GV.SC a 3 on delivery day. The residual scores here are the honest position of a programme on its first day.

6.2 Why each one is NEW, in one line each

The test from §1.7 — *would the existing risk's controls have prevented this?* — applied to all nine:

Risk	Nearest existing risk	Would its controls have caught this?	Verdict
VR-001 no Article 28 contract	none	No control in CGI-RSK-001 v1.0 addresses contracts	**NEW**
VR-002 concentration / correlated failure	R-002 ransomware (availability)	No — R-002's controls are endpoint hygiene and least privilege (backups are a recorded gap, CG-01), all inert against a provider region failure	**NEW**
VR-003 undisclosed fourth-party transfer	R-003 insider exfiltration	**No — CGI-POL-003 §4.5.2 four-hour leaver revocation is completely inert against a vendor API sync.** Different actor, mechanism, pathway and timing	**NEW**
VR-004 vendor-side breach of our data	R-005 CloudCo misconfiguration	No — R-005 is a Cypher Group Inc. configuration error, not a vendor compromise	**NEW**
VR-005 shadow IT procurement	none	No — this programme's own discovery exercise is what found it	**NEW**
VR-006 third-party AI retention, review and training	none	No. CGI-POL-001 §4.5 governs **AI used by staff**, not **AI vendors used on staff output**	**NEW**
VR-007 Tier 1 lock-in, no tested exit	none	No — v1.0 has no commercial or continuity-of-supply scenario	**NEW**
VR-008 vendor accounts surviving offboarding	**R-003**	**Partly. The four-hour SLA exists, is correct, and cannot be technically met on non-federated vendors.**	**Realises R-003 through a route its own control cannot reach.** Recorded separately so the vendor pathway is visible rather than buried in R-003's residual
VR-009 assurance decay	none	No — it is an operational risk **created by running a vendor programme at all**. It did not exist before Cypher Group Inc. began holding assurance evidence	**NEW**

Eight new. One realises an existing risk through a new pathway. VR-008 is the interesting one, and worth defending out loud: it could have been folded into R-003 as a likelihood increase. It is kept separate because **its treatment is**

different — R-003 is treated by the joiner-mover-leaver process, while VR-008 is treated by contractual SSO and SCIM requirements at Tier 1 renewal. **Risks that share a consequence but need different controls belong in different rows.**

6.3 The risk that stays High, and why that is deliberate

VR-004 — a vendor breach exposing Cypher Group Inc. customer data held outside the Cypher Group Inc. environment — is scored inherent 15 (Critical) and residual 12 (High). It is the only one of the nine that does not come down into Medium, and that is not an oversight.

- **Likelihood does not move (3 → 3).** Nothing Cypher Group Inc. does changes how likely a breach at a Tier 1 provider is. Assessment, contracts and tiering do not reduce the probability of someone else being attacked. **This is a right-of-bang risk almost in its entirety.**
- **Impact moves one band (5 → 4)**, bought by the 24-hour contractual notification clause, recorded incident contacts, and the vendor scenario added to the REC-12 tabletop. Learning fast is the only impact lever available.
- It therefore joins **R-004** and **R-005** as a residual High that is honest about its own limits. CGI-RSK-001 v1.1 will carry **three** residual High risks, not two, and the third one cannot be engineered away — only insured, contracted and rehearsed against.

> This is the answer to the interview question *"what can't you fix?"* — and having one is worth more than a register where everything conveniently reduces to Low.

6.4 Merge instructions for CGI-RSK-001 v1.1

Step	Action
1	Append **VR-001 to VR-009** to the CGI-RSK-001 risk sheet. Do **not** renumber R-001 to R-005; the VR prefix preserves provenance and makes the supplier-originated subset filterable.
2	Update **R-003** likelihood commentary to record the vendor pathway identified in **VR-008**, cross-referencing it rather than duplicating it.
3	Update **R-001** commentary to record that OfficeCo is the identity provider, so a compromise there is estate-wide rather than mailbox-scoped.
4	Add **control gap CG-06 — no third-party assurance or contractual control over suppliers** to the control gap list, and mark it **closed by CGI-TPR-001**. It is the first CG to be closed since the list was written.
5	Add the seven vendor KRIs (§6.5) to the CGI-RSK-001 KRI table, taking it from **7 to 14 indicators**.
6	Record **ACC-V01** (SchedulerCo) in the acceptance register alongside **ACC-001**, with its 15 Sep 2028 expiry.
7	Re-run the aggregate figures and restate the headline reduction.

Projected CGI-RSK-001 v1.1 position after merge:

	v1.0	Addendum	v1.1
Risks	5	9	**14**
Aggregate inherent	92	121	**213**
Mean inherent	18.40	13.44	**15.21**
Aggregate residual	44	78	**122**
Mean residual	8.80	8.67	**8.71**
Reduction	52%	36%	**43%**
Residual High or above	2 (R-004, R-005)	1 (VR-004)	**3**

> **Read the mean residual row carefully, because it is the most quietly impressive number in the whole portfolio.** The register nearly triples in size — from 5 risks to 14 — and the **mean residual barely moves, 8.80 to 8.71.** That is what it looks like when a new risk domain is brought inside an existing method rather than bolted on beside it. The aggregate rises because the company is now seeing more of its own exposure, not because it became more exposed.

6.5 Vendor key risk indicators

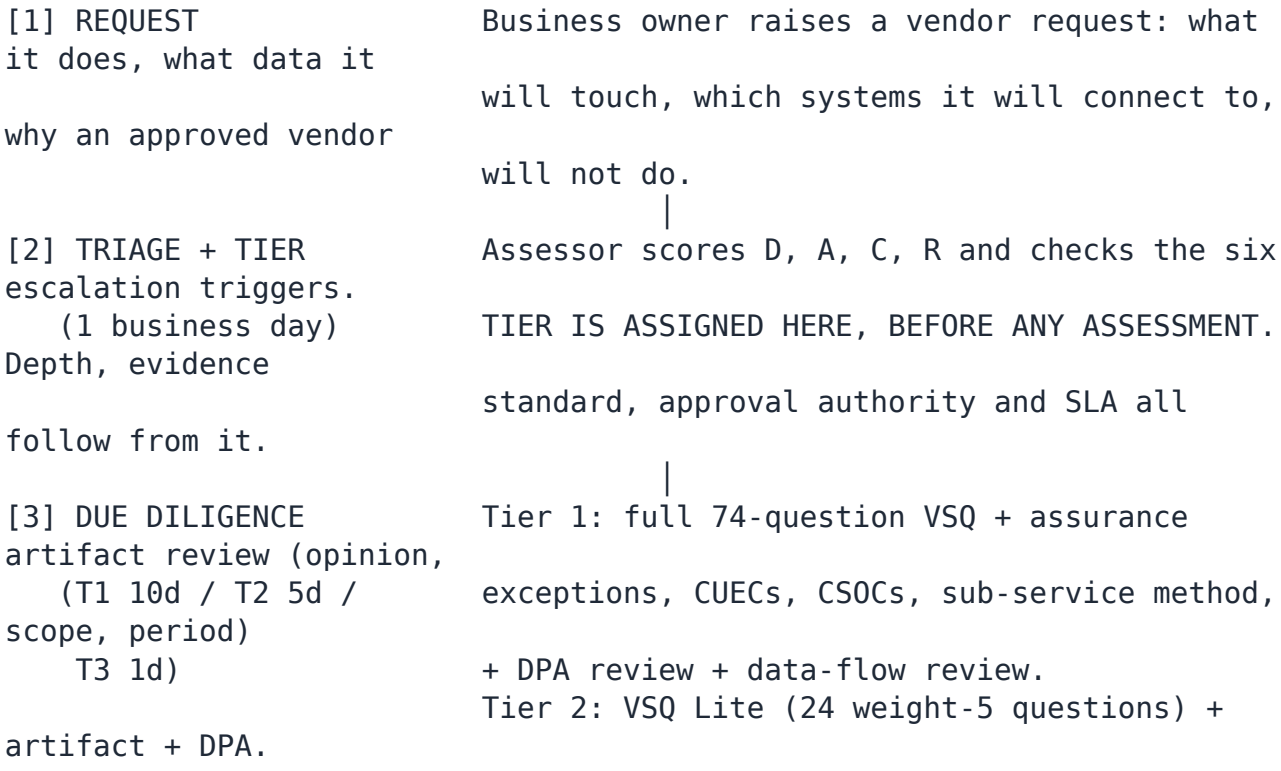
Seven indicators, extending the seven already in CGI-RSK-001 to fourteen. All are reportable at the quarterly security review that **REC-10** establishes, which is what eventually converts this programme from maturity 2 to maturity 3.

KRI ID	Indicator	Target	Escalation threshold	Owner (Job Title)	Frequency
KRI-V1	Percentage of vendors in the inventory with an executed DPA	100%	< 95%	Chief Technology Officer	Monthly
KRI-V2	Percentage of Tier 1 vendors with a completed assessment within cadence	100%	< 100%	Chief Technology Officer	Quarterly
KRI-V3	Percentage of Tier 1 assurance artifacts within period or bridged	100%	< 90%	Chief Technology Officer	Quarterly
KRI-V4	Number of vendors discovered outside the onboarding workflow (shadow IT) per quarter	0	> 1	Finance Manager	Quarterly
KRI-V5	Percentage of Tier 1 vendors federated to SSO with automated deprovisioning	100%	< 100%	IT Operations Manager	Quarterly
KRI-V6	Mean days from vendor request to onboarding decision, Tier 1	<= 15	> 25	Chief Technology Officer	Quarterly
KRI-V7	Number of Tier 1 vendors with no documented exit plan	0	>= 1	Chief Executive Officer	Semi-annual

KRI-V1 is the one to report first. It is currently **65%** — 11 of 17 vendors with an executed DPA — against a target of 100%. It is a single number, it is unambiguous, it moves fast, and it costs nothing to improve. **A KRI that a CEO can act on this month is worth more than four that need a tool.**

Part 7 — Onboarding / offboarding workflow and contractual clause checklist

7.1 Onboarding — the gate



```
                        Tier 3: 6-question attestation + DPA
confirmation.
                                  |
[4] SCORE + FINDINGS    Weighted score. Findings raised with severity,
owner, due date.
                        Two or more weight-5 Not Met = automatic Fail
regardless of score.
                                  |
[5] CONTRACT            Clause checklist (7.4) applied. DPA executed.
NO DPA, NO ONBOARDING -
                        this is the gate that makes VR-001
unrepeatable.
                                  |
[6] DECISION            Pass / Pass with conditions / Fail / Accept
with justification.
                        Approval authority per tier. Decision recorded
with a date and a name.
                                  |
[7] PROVISION           SSO federation where supported. Named business
owner assigned.
                        Data classification recorded. Added to the
offboarding checklist
                        BEFORE first use.
                                  |
[8] REGISTER            Inventory row created, all 17 mandated columns
populated.
                        Next Review Date diarised. Sub-processor feed
subscribed for T1.
                                  |
[9] REVIEW              T1 12 months · T2 18 months · T3 24 months,
plus on any material
                        change: new data type, new plan, acquisition,
breach, sub-processor
                        change, or a change of business owner.
```

Three gates, and each one exists because of a specific finding in this assessment:

Gate	Rule	The finding it prevents
Gate A — tier before assess	No assessment begins until a tier is assigned	Prevents the WriteCo outcome, where arithmetic would have under-scrutinised an AI processor reading Confidential text
Gate B — no DPA, no onboarding	No vendor is provisioned before the DPA is executed	Prevents **VR-001**. Five of the six DPA failures in this estate happened because provisioning came first and paperwork was going to follow
Gate C — offboarding list before first use	A vendor enters the offboarding checklist at provisioning, not at termination	Prevents **VR-008**. A vendor nobody recorded is a vendor nobody deprovisions

The SLA is a control, not a courtesy. Tier 1 in 15 business days, Tier 2 in 7, Tier 3 in 2. The largest single cause of shadow IT is a security process slower than the business need, so **VR-005 is mitigated by the SLA at least as much as by the policy.** A committed turnaround is the price of being allowed to refuse the workaround.

Worked example — CGI-VEN-017 through the workflow

StatusCo is the first vendor onboarded under this process, and it exists because **CGI-GAP-001 REC-14** requires a customer status page.

Step	What happened
1 Request	Head of Customer Success; purpose: incident and recovery communication to ~200 customers (closes **RC.CO**, currently 0)
2 Triage	D0 (Public content and subscriber emails only) · A1 · C0 · R0 = **1**. No trigger fires. **Tier 3**
3 Diligence	6-question attestation issued 15 Sep 2026
4 Score	Pending
5 Contract	**DPA in contract review — provisioning blocked at Gate B until executed**
6 Decision	Pending, Head of Customer Success to approve
7 Provision	Blocked
8 Register	Row created in advance with status `ONBOARDING`, so the vendor is visible in the register **before** it holds any data
Architecture note	**Deliberately not hosted on the platform's own cloud provider.** A status page that fails with the platform is not a status page. This is **VR-002** applied at design time rather than discovered later

7.2 Offboarding — the part everyone forgets

```
[1] TRIGGER              Contract termination · vendor replaced · service
discontinued ·
                         vendor acquired · business owner departs with no
successor named
                                  |
[2] DATA EXPORT          Export all Cypher Group Inc. data in a usable format
BEFORE any
                         access is disabled. This order is not negotiable -
access removed
                         first means data unreachable permanently.
                                  |
[3] ACCESS REMOVAL       Disable SSO assignment. Remove every non-federated
local account
                         individually, from the offboarding checklist created
at Gate C.
                         Revoke API keys, OAuth grants, webhooks and service
accounts
                         (CGI-POL-002 §4.5).
                                  |
[4] DATA DELETION        Issue the contractual deletion instruction. Obtain a
written
                         CERTIFICATE OF DELETION (VQ-73). Diary the deletion
deadline and
                         verify it, rather than assuming.
                                  |
[5] FINANCIAL            Cancel the payment instrument. A live card is how a
"terminated"
                         vendor keeps processing for another year - this is
exactly how
                         shadow IT persists after offboarding.
```

```
                          |
[6] REGISTER              Inventory status = Offboarded, with the date and the
deletion
                          certificate reference. THE ROW IS NOT DELETED. An
offboarded vendor
                          that held customer data is evidence, and a regulator
or customer may
                          ask about it years later.
                          |
[7] RISK                  Close or re-score any risk entry that named this
vendor.
```

Employee offboarding is a different workflow that shares a failure mode. When a person leaves, **CGI-POL-003 §4.5.2** requires revocation within four hours. That works for federated systems. For the vendors in this estate that are **not** federated — currently ChatCo, WikiCo, WriteCo and WhiteboardCo — there is no automated path, so each one must appear by name on the leaver checklist. **This is VR-008, and it is the reason the inventory carries an SSO-federation column at all.**

7.3 RACI

Activity	Business Owner	Assessor	CTO	CEO	Finance Manager
Raise vendor request	**R**	I	I		I
Assign tier	C	**R**	**A**		
Run assessment	C	**R**	**A**		
Review assurance artifact	I	**R**	**A**		
Negotiate and execute DPA	C	C	**R**	**A**	I
Approve Tier 1	C	C	**R**	**A**	I
Approve Tier 2	C	C	**A/R**	I	I
Approve Tier 3	**A/R**	C	I		I
Maintain the inventory	C	**A/R**	I		C
Expense and OAuth reconciliation (shadow IT)	I	C	C		**A/R**
Execute offboarding	**R**	C	**A**		**R** (payment)
Report KRIs at the quarterly review	I	**R**	**A**	I	C

R = Responsible · A = Accountable · C = Consulted · I = Informed

7.4 Contractual security clause checklist

These are the only controls Cypher Group Inc. will ever own over a third party, and they exist only before signature. Weight column: **M = mandatory for the tier · R = required, negotiable · O = seek, accept refusal with a recorded reason.**

#	Clause	What it must actually say	T1	T2	T3	ISO 27001:2022
1	**Data Processing Agreement**	Full GDPR Art. 28(3) content: subject matter, duration, nature and purpose, data types, data subject categories, documented-instructions-only, staff confidentiality, Art. 32 measures, assistance with data subject rights and breach notification, deletion or return at end of contract	**M**	**M**	**M**	A.5.20, A.5.34

#	Clause	What it must actually say	T1	T2	T3	ISO 27001:2022
2	**Breach notification within 24 hours**	A fixed maximum in hours, starting from the vendor's awareness, with defined minimum content. **Not "promptly", not "without undue delay"**	**M**	**M**	**M**	A.5.20, A.6.8
3	**Named security contact + out-of-hours route**	A person or rota, not a support portal	**M**	**R**	O	A.5.5
4	**Sub-processor list + 30 days' notice + right to object**	Current list appended to the contract; 30 days' prior written notice of change; a right to object with a termination remedy if unresolved	**M**	**M**	**R**	A.5.21, A.5.22
5	**Flow-down of equivalent obligations**	The vendor imposes materially equivalent terms on its own sub-processors	**M**	**R**	O	A.5.20
6	**Data residency and Art. 46 transfer mechanism**	Named countries; SCCs or adequacy identified; transfer impact assessment where applicable	**M**	**M**	**R**	A.5.34
7	**No AI training, no human review without consent**	Explicit prohibition on using Cypher Group Inc. data to train, fine-tune or evaluate any model, and on human review, by the vendor **or any AI sub-processor**	**M**	**M**	**M**	A.5.20, A.5.34
8	**Right of audit, or attestation in lieu**	An audit right, or a contractual commitment to provide a current SOC 2 Type II or ISO 27001 certificate annually **with its scope statement**	**R**	**R**	O	A.5.20, A.5.22
9	**Assurance refresh obligation**	The vendor provides its refreshed report within 30 days of issue, and a bridge letter on request. **This is the clause that treats VR-009**	**M**	**R**	O	A.5.22
10	**Encryption at rest and in transit**	Named minimum standards, not "industry standard"	**M**	**R**	O	A.8.24
11	**Data export on demand, in a documented format**	Machine-readable, documented, available without additional fee — the clause that makes an exit plan real	**M**	**R**	O	A.5.29
12	**Certified deletion on termination**	Deletion within a stated number of days, with a written certificate	**M**	**M**	**M**	A.8.10
13	**Transition assistance on exit**	Defined scope and duration of assistance, priced in advance	**R**	O	—	A.5.20
14	**SSO and SCIM support**	Federation and automated deprovisioning, so the CGI-POL-003 §4.5.2 four-hour SLA is technically achievable. **This clause treats VR-008**	**M** at renewal	**R**	O	A.5.16, A.5.18
15	**Customer-accessible audit logs**	The customer can retrieve administrative and access logs for its own tenant	**M**	**R**	O	A.8.15
16	**Cyber liability insurance**	Stated limit of indemnity, with a certificate on request	**R**	O	—	A.5.20
17	**Service levels with credits**	Availability commitment with a remedy, not an aspiration	**R**	O	—	A.5.30
18	**Notification of change of control**	Written notice of acquisition, with a termination right. **This clause treats VR-007**	**R**	O	—	A.5.22

> **Clause 2 is the one to defend in an interview.** *"Without undue delay"* is unenforceable and unmeasurable. **CGI-POL-005 §5.6.3 commits Cypher Group Inc. to notifying a supervisory authority within 72 hours of awareness. If a vendor is not contractually bound to a fixed number of hours, the start of that clock is outside the company's control** — and a statutory deadline you cannot start is a statutory deadline you will miss.

7.5 The CGI-POL-004 §4.2 amendment — closing the hole REC-15 named

REC-15 requires that permitted third-party destinations be added to the Handling Matrix. Proposed amendment, for approval by the CTO alongside this document:

Classification	Permitted third-party destinations	Prohibited
Public	Any vendor in the inventory	—
Internal	Any vendor in the inventory with an executed DPA	Any vendor not in the inventory
Confidential	**Tier 1 or Tier 2 vendors only**, with an executed DPA **and** a current assurance artifact on file	Tier 3 vendors · any vendor with no DPA · **any AI processor without the Clause 7 prohibition in force**
Restricted	**Tier 1 vendors only**, with an executed DPA, a current assurance artifact, and named written approval of the specific data flow by the CTO	Everything else

Plus one standing rule: **no data of any classification may be placed with a vendor that is not in the CGI-TPR-001 inventory.** That single sentence is what converts the inventory from a list into a control — and it is what makes "is this tool approved?" a question with an answer.

Part 8 — One-page executive summary

> **To:** Jerry Olugboye, Chief Executive Officer · **From:** O.S, Assessor · **Date:** 15 September 2026 **Subject:** Who we depend on, what we know about them, and what we have signed *(Simulated case study.)*

We depend on 17 companies. We had assessed none of them.

CGI-GAP-001 scored supply chain risk **0 out of 4** — the only zero in the assessment that is also a direct revenue blocker. This programme closes it.

The three things that matter

1. Six of our seventeen vendors process our data with no contract governing it. Five have no Data Processing Agreement; one is pending. Four of the six already hold Confidential data. This is not a future risk — **it is a GDPR Article 28 non-conformity that exists today**, and it is the first thing any enterprise customer's own vendor assessment of us would find. **Fixing it costs nothing but signatures.**

2. Our most-used communication tool failed its assessment, and every reason was ours. ChatCo scored **65%** with **five Critical or High findings**: no DPA, no contractual breach-notification commitment, no automated account removal, AI features processing our message content under no terms, and unlimited retention of everything ever posted. **ChatCo's own security is not the problem.** Nobody executed the contract, checked the plan, or read the terms. Remediation is **approximately USD 3,600 a year**, and six of the eight actions are free.

3. Our best-certified vendor passed only with conditions — and all four conditions are ours. CloudCo holds every relevant certification. Its SOC 2 report also lists four controls **it assumes we are performing**: organisation-wide audit logging, root-account MFA, least-privilege access review and encryption management. **We are performing none of them.** That means the clean report in our files does not actually cover how we use the service. **Our vendor's certificate is our vendor's control, not ours** — and it is the same gap that keeps **R-005 at High** in our risk register.

The portfolio picture

Vendors in scope	**17** — 3.4× the five we thought we had
Tier 1 / 2 / 3	**7 / 6 / 4**
No executed DPA	**6 (35%)**
No assurance artifact held	**4 (24%)** — three of these vendors publish one; we never asked
Found outside any procurement process	**2** — both AI tools processing customer conversations and typed text, bought on expenses
Aggregate inherent vendor risk	**159** across 17 vendors (mean 9.35)
New risks for the register	**9** — taking CGI-RSK-001 from 5 risks to 14
Risks that stay High after treatment	**1 new** (VR-004, vendor breach) — joining R-004 and R-005
Concentration	**Five vendors, including our monitoring, our ticketing and our runbooks, sit on the same cloud as our platform.** One regional failure removes the platform *and everything we would use to detect, diagnose and communicate about it.**

What I am asking for

	Ask	Cost
Now (30 days)	Execute the six outstanding DPAs. Disable the AI features on ChatCo until terms are in place. Set retention limits.	**Nil. Signatures and settings.**
By 15 Dec 2026	Approve the ChatCo plan upgrade for SSO and SCIM. Accept and assign the four CloudCo assumed controls. Decide on ChatCo: remediate or migrate.	**~USD 3,600/yr**, inside the USD 32,100 already costed in CGI-RSK-001
Standing	Approve this tiering model and the "no DPA, no onboarding" gate. Approve the CGI-POL-004 §4.2 amendment. Receive seven vendor KRIs at the quarterly review REC-10 creates.	**Your signature, and 15 minutes a quarter**

What it buys

GV.SC moves from 0 to 2 — our declared target — closing this gap entirely in one cycle. Overall maturity moves from **1.23 to 1.32 out of 4.00**. More usefully: **we become able to answer the vendor management section of an enterprise security questionnaire**, which is currently one of five sections that stop us bidding.

The single sentence for the board: *We have never been unable to answer "is our data safe with our vendors?" — we have been unable to answer "which vendors?"*

---

§ The answer to the commissioning question: GV.SC 0 → 2

This work was commissioned by **CGI-GAP-001 REC-15** to close **GAP-006**. The explicit question is what the Category scores once the programme is delivered. The answer is **2**, not 3, and the reasoning matters more than the number.

The rule that decides it

CGI-GAP-001 §3.1, applied unchanged:

Score	Level	What is required
0	Not Performed	The outcome is not achieved in any form
1	Initial / Ad Hoc	Occasional, reactive, person-dependent, unevidenced
2	**Documented / Repeatable**	**An approved policy, standard or procedure exists, ownership is assigned, the expectation is communicated. Design effectiveness without operating effectiveness**

Score	Level	What is required
3	Defined and Operating	Performed **consistently on a defined schedule**, each occurrence producing **retained evidence**
4	Managed and Measured	Metrics with thresholds, reported to leadership, driving documented change

> **The governing rule, verbatim from CGI-GAP-001 §2.2: "An approved, published policy that nobody has evidenced executing scores a 2, not a 3."**

Applying it honestly

Delivered today	Satisfies	Does it earn a 3?
Tiered inventory of 17 vendors, all columns populated	Documented	No
Published tiering model, applied mechanically	Repeatable	No
74-question questionnaire with evidence and weights	Documented	No
Three completed assessments with decisions and dates	**First evidence of execution**	Not yet — three is not a cadence
Nine risks scored into the register	Documented	No
Onboarding gate, offboarding workflow, RACI, clause checklist	Documented, owned	No
Review cadence defined: 12 / 18 / 24 months	Scheduled	**The reviews have not happened yet**
Seven KRIs with targets, thresholds and owners	Defined	**None has been measured or reported**

GV.SC = 2. Documented and Repeatable.

Everything required for a 2 is present: an approved procedure, assigned ownership, a communicated expectation. What is absent is the thing a 3 requires — **a completed cycle of reviews on the defined schedule, each producing a dated, retained artifact.** On 15 September 2026 that cycle has run three times out of seventeen and the first Tier 1 re-review is twelve months away.

Reconciliation against the CGI-GAP-001 declared target

GV.SC current, CGI-GAP-001 v1.0	**0** (two fragments only — CGI-POL-001 §4.6.1 and CGI-POL-003 §4.6)
GV.SC **declared target**, CGI-GAP-001 §3.2	**2**
GV.SC after CGI-TPR-001	**2**
Remaining gap	**0 — target met in a single cycle**

CGI-GAP-001 §3.2 set GV.SC's target at 2 rather than 3 and flagged it as the one target that would look too low to an experienced reader, with the reason stated: *"a target of 3 in one cycle would require a full vendor assurance programme that does not yet have an owner or a budget. A target of 2 — a tiered vendor inventory with assurance artifacts on file — is what can actually be delivered."*

That is precisely what was delivered. The target was set honestly and has been met exactly. The two fragments GAP-006 recorded — the CTO-approval rule and the third-party access sponsor rule — are now absorbed into a complete, owned procedure. That is the difference between a clause and a capability, and it is what turns a 0 into a 2. CGI-GAP-001 §7 also flagged GV.SC for **re-targeting to 3 in the next cycle**; §below says what that costs.

Effect on the overall score

	Value	Working
CGI-GAP-001 v1.0 overall	**1.23**	current sum 27 ÷ 22 Categories = 1.2273
GV.SC contribution change	**0 → 2**	+2 to the current sum

	Value	Working
CGI-GAP-001 v1.1 overall	**1.32**	29 ÷ 22 = 1.3182
Movement	**+0.09**	

One Category moves. Nothing else is claimed, and the restraint is deliberate. This programme creates *prerequisites* elsewhere — the inventory is a prerequisite for **REC-05 (ID.AM)**, the §4.2 amendment supports **PR.DS**, the vendor incident contacts support **RS.CO** — but a prerequisite is not a score. **ID.AM does not move because a vendor inventory is not an asset inventory**; it is one input to the one REC-05 must still build. Claiming four Categories moved because one project touched them is the single most common way a maturity scorecard loses its credibility, and it would be caught in an interview.

What it would take to reach 3, and when

Requirement for maturity 3	Evidence needed	Earliest
Tier 1 reviews performed on cadence	7 dated, signed review records	**Sep 2027**
Tier 2 reviews performed on cadence	6 dated review records	Mar 2028
Onboarding gate demonstrably enforced	≥ 3 vendors through the full workflow with decision records	Q1 2027
Shadow-IT reconciliation operating	4 quarterly expense and OAuth reconciliation records	Q3 2027
KRIs reported to leadership	4 quarterly minutes from the REC-10 review	Q3 2027
All findings tracked to closure	Closed-finding evidence for VRA-2026-001 and -002	Dec 2026

Realistic date for GV.SC = 3: Q3 2027, gated by the Tier 1 review cycle. A 4 requires the KRIs to drive a documented change of approach and is not proposed in this cycle, consistent with CGI-GAP-001 §3.2's decision to target 4 in no Category.

Appendix A — Verification, assumptions and limitations

A.1 Verification performed

Every figure in this document was computed programmatically and the workbook was recalculated in a spreadsheet engine before delivery. Nothing below was checked by eye.

Check	Result
Vendor count ≥ 15, including all five named stack providers	✅ 17 vendors; CloudCo, CodeCo, ChatCo, OfficeCo and PaymentsCo all present
All 17 mandated inventory columns present, in the required order, in columns A–Q	✅
Extra governance columns appended **after** the mandated set	✅ from column R
Every tier recomputed from the published model, not hand-assigned	✅ 7 / 6 / 4
Every tiering factor within 0–3; every likelihood and impact within 1–5	✅
Questionnaire ≥ 60 questions across ≥ 12 domains	✅ **74 questions, 16 domains**
Every question carries response type, evidence requirement, risk weight, ISO Annex A and CSF 2.0	✅ 74 of 74 on all five
Three assessments at contrasting outcomes	✅ Fail / conditional pass / accepted
Assessment arithmetic reconciles (Met + Partial + Not Met + N/A = questions applied)	✅ 74 / 74 / 6
Weighted scores recomputed from deduction ÷ maximum	✅ 65% / 89% / 92%
Addendum uses the identical 5 × 5 method and thresholds as CGI-RSK-001	✅

Check	Result
No risk has residual greater than inherent	✅ 9 of 9
At least one risk honestly remains High after treatment	✅ VR-004 residual 12
Every addendum risk declares NEW or REALISES	✅ 8 new, 1 realises R-003
Merge arithmetic for CGI-RSK-001 v1.1	✅ 92+121=213 inherent, 44+78=122 residual, 43% reduction, mean residual 8.71
GV.SC movement reconciled against the CGI-GAP-001 declared target	✅ 0 → 2, target 2, gap 0; overall 27÷22=1.23 → 29÷22=1.32
Workbook formulas are formulas, not hardcoded values	✅ 207 formulas (rebuilt 16 Sep 2026)
Workbook recalculated; zero `#REF!`, `#DIV/0!`, `#VALUE!`, `#NAME?`	✅ **0 errors across 9 sheets**
Every owner is a job title, never a named individual	✅
Case-study notice present on the document and the workbook	✅
Real-company assurance and contract statuses labelled as invented	✅
Tables paste cleanly — one value per cell, no merged cells	✅

A.2 Assumptions

ID	Assumption	Basis
VA-01	CGI-POL-004's four classification tiers are **Public · Internal · Confidential · Restricted**, Restricted highest	**Confirmed 15 Sep 2026** against CGI-POL-004 v1.0 §4.1.1, which uses exactly these four tiers
VA-02	Cypher Group Inc. names its sub-processors to customers in its own customer DPA	Standard for B2B SaaS; drives trigger T1-e
VA-03	Approximately 9,000 end-user identities across ~200 customers (mean 45 per customer)	Derived from the CGI-RSK-001 A-01 customer count; used only to size LoginCo's impact
VA-04	The USD 32,100 year-one budget from CGI-RSK-001 is available but still unapproved	CGI-GAP-001 GAP-003. The ChatCo remediation of ~USD 3,600/yr is costed inside it
VA-05	No cardholder numbers are held (AVD-001) and no PHI is processed	CGI-POL-004 §4.1.4; CGI-RSK-001 AVD-001
VA-06	Inherent vendor risk = likelihood of a vendor-originated incident materially affecting Cypher Group Inc. within 12 months × impact, **before** any Cypher Group Inc. assurance activity	Stated so the score is falsifiable

A.3 Limitations

- **This is a documentation and contract review, not a technical assessment of any vendor.** No vendor environment was tested, no configuration inspected, no scan run. Where this document says a control is absent it means no evidence of it was produced.
- **All vendor responses are modelled.** In a real engagement, sections 5.1 to 5.3 would carry the vendor's actual returned questionnaire and the actual report extracts. The **method** shown is real; the **responses** are constructed to demonstrate three contrasting outcomes.
- **Fourth-party visibility stops at the sub-processor list.** Where a report uses the carve-out method, the CSOC controls are assumed. This is a structural limitation of vendor assurance, not of this assessment, and it is why VR-003 exists rather than being treated as closed.
- **Residual scores assume the controls in this document will operate.** On 15 September 2026 most of them have never run. That is why GV.SC scores 2, and it is why the addendum claims a 36% reduction rather than the 52% the policy pack claimed.
- **One assessor.** A second reviewer could reasonably differ by one band on individual vendors. The published tiering model and risk weights exist to keep that variance bounded.

Appendix B — Glossary

Term	Definition
AICPA	American Institute of Certified Public Accountants. Publishes the SOC framework and the Trust Services Criteria
Assurance artifact	Independent evidence about a vendor's controls — a SOC 2 report, an ISO 27001 certificate with its scope statement, a penetration test summary. A vendor's own questionnaire answer is not one
BAA	Business Associate Agreement. HIPAA contract between a covered entity and a business associate handling PHI. 45 CFR §164.502(e), §164.308(b)
Bridge letter	A vendor-signed statement covering the gap between a SOC 2 period end and today, asserting no material change. Not audited
CAIQ	Consensus Assessments Initiative Questionnaire (Cloud Security Alliance), mapped to the Cloud Controls Matrix; current line CCM/CAIQ v4.1
Carve-out method	SOC 2 treatment excluding a sub-service organisation's controls from the description and the opinion, listing CSOCs instead
CCM	Cloud Controls Matrix. CSA's cloud control framework
Concentration risk	The risk that apparently independent vendors share a common underlying provider, so one failure removes several at once
Controller	GDPR. The party determining the purposes and means of processing personal data
Covered entity	HIPAA. A health plan, healthcare clearinghouse, or healthcare provider transmitting health information electronically
CSA	Cloud Security Alliance. Publisher of the CCM, CAIQ and the STAR registry
CSOC	Complementary Subservice Organization Control. A control the report assumes is operating at a carved-out sub-service organisation
CUEC	Complementary User Entity Control. A control the SOC 2 assumes **you** operate. If you do not, the opinion does not cover your usage
DORA	EU Digital Operational Resilience Act. Article 28 register of information; Article 30 mandatory contractual provisions
DPA	Data Processing Agreement. GDPR Article 28(3) contract between controller and processor
ePHI	Electronic Protected Health Information
Fourth party	Your vendor's vendor, from your position. Positional, not legal. Continues as Nth party
GDPR Art. 28	Controller–processor relationships. 28(2) sub-processor authorisation · 28(3) mandatory DPA content · 28(4) processor stays fully liable for its sub-processor
HHS OCR	US Department of Health and Human Services, Office for Civil Rights. Enforces HIPAA
HIPAA	Health Insurance Portability and Accountability Act (US)
Inherent vendor risk	Exposure from a vendor before any of your assurance activity or contractual protection. Drives nothing about the tier; recorded separately
ISMS	Information Security Management System. The object ISO 27001 certifies
Left of the bang	Shorthand for the likelihood/impact test: a control acting before the event reduces likelihood; one acting after reduces impact
NIS2	EU Directive on measures for a high common level of cybersecurity. Article 21(2)(d) makes supply chain security an explicit obligation
PHI	Protected Health Information. HIPAA-regulated individually identifiable health information; 18 identifiers
Processor	GDPR. A party processing personal data on a controller's documented instructions
Residual vendor risk	Inherent vendor risk after assurance evidence, contractual terms and your own compensating controls
SIG	Standardized Information Gathering questionnaire (Shared Assessments). SIG Core and SIG Lite; refreshed annually

Term	Definition
SOC 2	System and Organization Controls report on a service organisation's controls against the Trust Services Criteria. **Not a certification**
SoA	Statement of Applicability. The ISO 27001 document justifying inclusion or exclusion of each Annex A control. Built in Project 5
STAR registry	CSA's public CAIQ registry. Level 1 self-assessment; Level 2 third-party audited
Sub-processor	GDPR. A processor engaged by a processor
Sub-service organisation	SOC 2 term. A vendor whose controls are necessary for the service organisation's control objectives to be met
Tiering	Classification of vendors by the impact of their failure, determining assessment depth and review cadence. Performed **before** assessment
Trust Services Criteria	The five SOC 2 criteria: Security (mandatory), Availability, Processing Integrity, Confidentiality, Privacy
Type I / Type II	SOC 2 report types. Type I = design at a point in time (≈ maturity 2). Type II = design **and operating effectiveness** over a period (≈ maturity 3)
VQ-nn	A question in CGI-TPR-002, the vendor security questionnaire
VR-nnn	A vendor risk in the CGI-RSK-001 v1.1 addendum
VRA-yyyy-nnn	A completed vendor risk assessment

Source documents

ID	Document	Version	Status
CGI-POL-001 to -005	Startup Security Policy Pack	1.0	Approved
CGI-TRK-001	Sign-off and Training Tracker	current	60% acknowledged, 80% MFA
CGI-RSK-001	Master Information Security Risk Register	1.0	Approved — **v1.1 pending this addendum**
CGI-GAP-001	NIST CSF 2.0 Gap Assessment and Maturity Scorecard	1.0	Approved
CGI-TPR-001	**This document**	1.0	Final — issued for management review
CGI-TPR-002	Vendor Security Questionnaire	1.0	Issued
NIST CSWP 29	The NIST Cybersecurity Framework (CSF) 2.0	2.0	Published 26 Feb 2024
NIST SP 800-30 Rev. 1	Guide for Conducting Risk Assessments	Rev. 1	Referenced for the 5 × 5 method
ISO/IEC 27001:2022	Information security management systems — Requirements	2022	Referenced for Annex A mapping
Regulation (EU) 2016/679	GDPR — Articles 28, 30, 32, 33, 46	—	Referenced

End of CGI-TPR-001 v1.0. Prepared by O.S. Approved by Jerry Olugboye. Simulated case study data.